

DECEMBER 19, 2022



HACKER ACADEMY LTD

APPLICATION PENTEST & SECURITY ASSESSMENT REPORT

FOR XYZ REALITY LTD

HACKER ACADEMY LTD
<https://hackeracademy.uk>



1 TABLE OF CONTENTS

1 EXECUTIVE SUMMARY.....	- 1 -
2 PROJECT OVERVIEW.....	- 3 -
2.1 VULNERABILITIES.....	- 4 -
2.2 ROOT CAUSE ANALYSIS.....	- 5 -
2.3 SCOPE OF ENGAGEMENT	- 6 -
2.4 ASSESSMENT OBJECTIVES	- 8 -
2.5 CONTACT INFORMATION	- 8 -
2.6 CONFIDENTIALITY STATEMENT	- 8 -
2.7 DISCLAIMER	- 8 -
3 TESTING METHODOLOGY	- 10 -
3.1 NARRATIVE OF THE TESTS	- 11 -
4 SUMMARY OF VULNERABILITIES.....	- 13 -
5 FINDINGS.....	- 16 -
5.1 API AND APPLICATIONS FINDINGS	- 17 -
5.1.1 INSUFFICIENT ANTI-AUTOMATION.....	- 18 -
5.1.2 BROKEN ACCESS CONTROL	- 24 -
5.1.3 TLS VERSION 1. AND 1.1 PROTOCOL DETECTION	- 30 -
5.2 AZURE CLOUD SECURITY CONTROLS	- 37 -
5.2.1 IDENTITY AND ACCESS MANAGEMENT.....	- 38 -
5.2.2 STORAGE ACCOUNTS.....	- 47 -
5.2.3 DATABASE SERVICES.....	- 51 -
5.2.4 LOGGING AND MONITORING.....	- 51 -
5.2.5 NETWORKING	- 53 -
5.2.6 VIRTUAL MACHINES	- 64 -
5.2.7 KEY VAULT	- 64 -
5.2.8 APPSERVICE.....	- 65 -
6 APPENDIX.....	- 80 -
6.1 TEST CASES.....	- 80 -
6.1.1 INFORMATION GATHERING	- 80 -
6.1.2 CONFIGURATION MANAGEMENT	- 80 -
6.1.3 AUTHENTICATION	- 81 -
6.1.4 SESSION MANAGEMENT.....	- 82 -
6.1.5 AUTHORIZATION	- 83 -



6.1.6	DATA VALIDATION	- 83 -
6.1.7	DENIAL OF SERVICE	- 85 -
6.1.8	SPECIFIC RISKY FUNCTIONALITY.....	- 85 -
6.1.9	ERROR HANDLING.....	- 85 -
6.2	OWASP TOP 10	- 86 -
6.2.1	A1: INJECTION	- 86 -
6.2.2	A2: BROKEN AUTHENTICATION	- 86 -
6.2.3	A3: SENSITIVE DATA EXPOSURE	- 86 -
6.2.4	A4: XML EXTERNAL ENTITIES (XXE).....	- 86 -
6.2.5	A5: BROKEN ACCESS CONTROL	- 86 -
6.2.6	A6: SECURITY MISCONFIGURATION.....	- 87 -
6.2.7	A7: CROSS-SITE SCRIPTING (XSS).....	- 87 -
6.2.8	A8: INSECURE DESERIALIZATION	- 87 -
6.2.9	A9: USING COMPONENTS WITH KNOWN VULNERABILITIES.....	- 87 -
6.2.10	A10: INSUFFICIENT LOGGING & MONITORING	- 87 -
6.3	USED TOOLS	- 89 -
6.4	ROOT CAUSES	- 90 -
6.5	TERMINOLOGY.....	- 91 -



1 EXECUTIVE SUMMARY

Penetration Test and Security Assessment which were conducted between November 2022 and December 2022 were based around the scope of work detailed in the *Scope of Engagement* section listed below. Multiple tests and audit were conducted against the targeted systems involving both automated scanning and manual testing, in order to identify a range of possible vulnerabilities and any potential misconfiguration of the systems.

Within the scope of the project, we can summarise the performed works we have shared in the *Narrative of the Tests* section in details as follows:

- Grey-box and Black-box penetration testing of Web applications and APIs
- Security audits of Microsoft Azure where the servers and applications are hosted.
- Vulnerability scans of external network assets

When performing black-box and grey-box penetration testing of API, Web applications, we identified some minor issues that need to be addressed, such as a lack of protection against brute force attacks etc. The criticality levels of these findings are all Medium, so there is nothing to panic about them.

In the security tests, besides all the components in the OWASP Top 10, business logic vulnerabilities were also tested, such as;

- Applicability of injection attacks that threaten many other applications such as XSS, SQLi, XXE,
- Whether different tenants can access each other's data,
- Whether sensitive data can be leaked from the system,
- Any security misconfigurations,
- Using Components with known vulnerabilities

etc.

The software is particularly well controlled for input validation and output encoding. Therefore, it was observed that **the application was not affected by any injection attack in the security tests.**

Although there are many different tenants using the application and different projects belonging to these tenants, it has been confirmed as a result of tests conducted that user who are not granted access cannot access other user data.



One of the most important results of this test is that, there is no significant security findings, and fixing the detected security findings will not cause a change in the architecture of the application.

Although IAM functions are properly configured within the application, the first finding in the report was that access control to other components of the web server that underpins the application was not done properly enough.

After eliminating a few false-positives in the report of vulnerability scans carried out from the external network for servers and systems, it was seen that there were no even high or critical-level security findings. In addition to the Penetration Test and Security Assessment Report, you can also find the Microsoft Azure Cloud Providers audit based on the CIS results attached.

Since there is no de facto tool to perform Azure security checks, we prepared custom-made scripts and used open-source projects that check the [Microsoft Azure Cloud Providers](#) topics during the penetration test. You can access the details of the tools in the **Used Tools** section. The output of the Azure security benchmarks measures Azure Cloud which describes best practices, makes implementation recommendations, and goes into detail about products and services. The framework aims to help you design your Azure Cloud deployment so that it best matches your business needs. It seems that you have already passed most security checks in the Azure CIS Benchmark, and on the other hand, you must take corrective actions for a small number of failed items. For your development and deployment environment, based on your priorities, you should decide which items in this output need to be fixed, considering the Azure CIS benchmark to be the best practice.

The accounts used during the penetration test should be **disabled and deleted** after the project is finalized.



2 PROJECT OVERVIEW

This project consists of security testing and auditing of the Web application, the APIs, and cloud infrastructure. In the previous work, penetration testing was carried out for WEB, APIs and Cloud infrastructure.

Resource Name ↑	Actions ↑
Virtual Network (9)	
 webgl-windows_group-vnet	Expand
 vm-hsc-converter_group-vnet	Expand
 staging-network	Expand
 dev-network	Expand
 rg-kubernetes-dev-vnet	Expand
 rg-hsc-dev-webgl-vnet	Expand
 rg-hsc-dev-jenkins-vnet	Expand
 powerbi_group-vnet	Expand
 prod-network	Expand
Load Balancer (3)	
 kubernetes	Expand
 kubernetes	Expand
 kubernetes	Expand



2.1 VULNERABILITIES

During the penetration test and security assessment of XYZ REALITY LIMITED Infrastructure and web applications/APIs, we have found a total of **3 Medium severity level vulnerabilities**. All Vulnerabilities were identified as Medium.

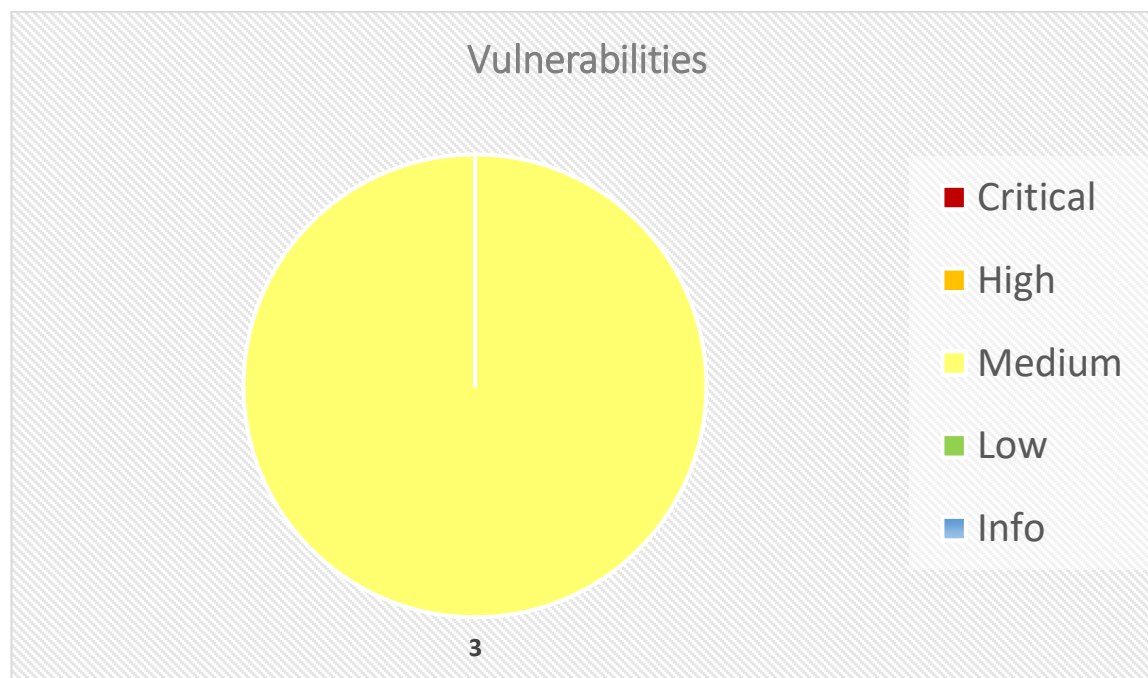


FIGURE 1 - VULNERABILITY CHART



2.2 ROOT CAUSE ANALYSIS

Identifying the root cause of a security issue is important to an effective and durable remediation strategy. Based on the testing performed, we have identified the following as the root causes for these security issues

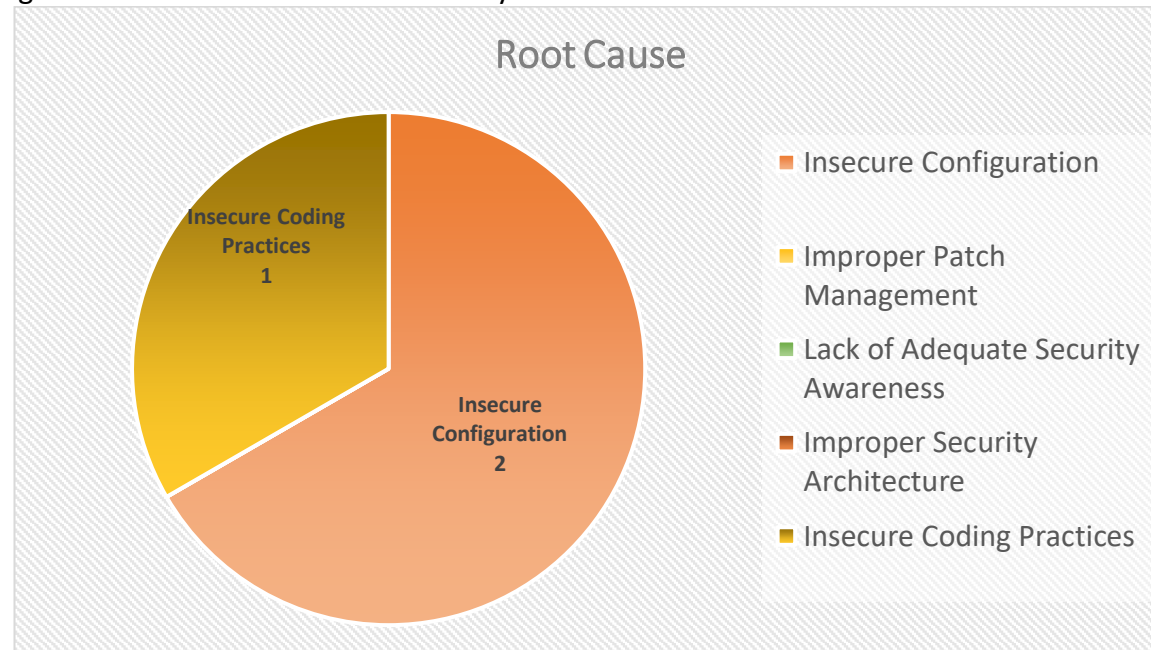


FIGURE 2 - ROOT CAUSES



2.3 SCOPE OF ENGAGEMENT

The following assets were identified within the scope for penetration tests. Below are all the domains and subdomains that we discovered from commercial and other open-source threat intelligence services, in addition to the domains provided us.

Domain
xyzreality.com
_domainconnect.xyzreality.com
autodiscover.xyzreality.com
blog.xyzreality.com
careers.xyzreality.com
cloud.xyzreality.com
demo.xyzreality.com
enterpriseenrollment.xyzreality.com
enterpriseregistration.xyzreality.com
ftp.xyzreality.com
lyncdiscover.xyzreality.com
msoid.xyzreality.com
pages.xyzreality.com
sip.xyzreality.com
staging.xyzreality.com
training.xyzreality.com
www.training.xyzreality.com
vpn.xyzreality.com
webinar.xyzreality.com
www.xyzreality.com



Domain
holosite.dev
api.holosite.dev
em7757.holosite.dev
frontend.holosite.dev
jenkins.holosite.dev
prod.holosite.dev
test.holosite.dev
upload.holosite.dev
webtrctest.holosite.dev
www.holosite.de

Applications served in all subdomains were scanned through a vulnerability scanner as well as manual security auditing tools.

All scans and security audit were carried out over the following IP addresses.

Hacker Academy IP addresses
18.169.133.231
18.169.222.212
90.152.1.37



2.4 ASSESSMENT OBJECTIVES

Hacker Academy Ltd worked to achieve the following objectives based upon the agreed **Scope of Engagement** listed above:

- Perform a security assessment against the targets specified in the **Scope of Engagement**.
- Prioritise vulnerabilities based upon ease of exploitation and severity.
- Provide recommendations to improve security practice in line with the industry best practice.
- Deliver a manageable and accurate report.

2.5 CONTACT INFORMATION

Any further questions regarding this report should be directed to Hacker Academy Ltd. Contact details are as follows:

Name Muharrem Aydin
Email aydin@hackeracademy.uk
Phone +44 7393 939406

2.6 Confidentiality Statement

This document is the exclusive property of XYZ REALITY LIMITED and Hacker Academy Ltd. This document contains proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, in any form, requires consent of both XYZ REALITY LIMITED and Hacker Academy Ltd.

2.7 Disclaimer

A Penetration Testing and Vulnerability Scan is considered a snapshot in time. The findings and recommendations reflect the information gathered during the assessment and not any changes or modifications made outside of that period.



Time-limited engagements do not allow for a full evaluation of all security controls. Hacker Academy Ltd prioritised the assessment to identify the weakest security controls an attacker would exploit. Hacker Academy Ltd recommends conducting similar assessments on an annual basis by internal or third-party assessors to ensure the continued success of the controls.

Hacker Academy provides all clients with all report information gathered during testing. This includes Nessus files and full vulnerability scans in detailed formats. These reports contain raw vulnerability scans and additional vulnerabilities not exploited by Hacker Academy. The reports identify hygiene issues needing attention but are less likely to lead to a breach, i.e., defence-in-depth opportunities. For more information, please see the documents in the attached files labelled “Additional Scans and Reports”



3 TESTING METHODOLOGY

After the engagement was signed between the parties, the industry-standard methodologies such as The OWASP (Open Web Application Security Project), The PTES (Penetration Testing Methodologies and Standards and The OSSTMM (Open-Source Security Testing Methodology Manual) and CIS Microsoft Azure Foundations Benchmark were used to perform the pentest and security assessments.

As the first step of these tests, we've used host and service discovery tools to map infrastructure topology. The servers and services found were scanned with vulnerability scanning software. Thus, the presence of security vulnerabilities that could be exploited remotely for these servers was checked. The vulnerabilities discovered were also attempted to be exploited manually.

The vulnerability scanning process was carried out for services that are accessible remotely. No local scan was performed.

On the penetration testing side of the application and API, the data was collected by using scanners, process monitors, network proxies and crawlers. This data contains information about operating systems of servers, technologies used in the application development etc. Then applications are scanned by dynamic application security testing (DAST) tools. Since automated tools may produce some false positives, the discovered vulnerabilities are analysed in detail. We've used HTTP proxy tools to eliminate false-positives and to perform manual security assessment according to OWASP Application Security Verification Standard 4.0.

We have performed penetration testing with several users with different roles like unauthenticated, authenticated, and privileged accounts.



3.1 NARRATIVE OF THE TESTS

The tests carried out within the scope are as follows:

External Vulnerability Scans

Network vulnerability scanning is useful to obtain a snapshot in time of the network services offered and the vulnerabilities they may contain. A remote scan is performed against the external points of presence.

External vulnerability scanning was performed using Tenable Nessus Professional, the vulnerability scanner software detailed in the *Used Tools* section. Nessus plugins were updated with the most up-to-date versions before scans. A new profile was created to scan all TCP and UDP ports. External vulnerability scans can determine local exposures on the target system.

When we reviewed the vulnerability scanning report, we realized that some of the findings were false-positive. A false positive means that the results say you have the condition you were tested for, but you really don't. Such results create noise and result in unnecessary remediation works. After eliminating a few false positives in the report of vulnerability scans carried out from the external network for servers and systems, it was seen that there were **a Medium-level security findings**.

Application Security Test with different roles (Unauthenticated/ Authenticated)

Application security tests were performed with several users in different roles according to the OWASP Application Security Verification Standard 4.0.2. These users have been created by the Izigo in order to perform the pentest.

The OWASP Application Security Verification Standard (ASVS) Project provides a basis for testing web application technical security controls and also provides developers with a list of requirements for secure development.

OWASP API Security Top 10 (2019), which is designed to address the ever-increasing number of organizations that are deploying potentially sensitive APIs as part of their software offerings, and Top 10 Web Application Security Risks (2017) were used to check potential security findings. We used both automatic and manual testing tools, which are described in the *Used Tools* section, the output of these security tools was consolidated before reporting.

The user accounts that we use during testing are as follows:



TABLE 1 - USED ACCOUNTS

Roles	
User	emre@hackeracademy.uk
User	info@hackeracademy.uk

Apart from these, some temporary e-mail accounts were also used to perform the registration process.

Apart from the API endpoints served in Web application which specified in Swagger, manual tools and wordlists are used to determine the presence of any of the hidden or forgotten endpoints located on the Application server.

When testing endpoints in the API, different tenants or different users within the same tenant have been tested to see if someone can take actions such as accessing, deleting, etc., on any resources according to their authorization level.

During API security tests, manual operations were carried out as much as possible, especially to discover business logic problems.

Manual verification was performed with Kali Linux 2022.3 operating system and tools installed on it.



4 SUMMARY OF VULNERABILITIES

The table below contains a high-level summary of the security weaknesses identified in this report. Findings are ordered according to severity levels which are explained in the *Testing Methodology* section.

TABLE 2 VULNERABILITY MATRIX

Ref. No	Vulnerability	
5.1.1	Insufficient Anti-Automation	MEDIUM
5.1.2	Broken Access Control	MEDIUM
5.1.3	Table of Contents	MEDIUM

The anatomy of the tests is explained in the *Narrative of the Tests* section in details. In the *Summary of Vulnerabilities* section, the results are summarised in a matrix that contains primarily the component names and the vulnerabilities found. In the matrix, the empty boxes indicate that there is no vulnerability in the corresponding component while,



CRITICAL	Indicates there is a critical severity level vulnerability in the corresponding component. These vulnerabilities can be exploited by attackers remotely and can result in the exploitation of the whole system. Risk Score: 9.0 - 10.0
HIGH	Indicates there is a high severity level vulnerability in the corresponding component. These are the ones that are difficult to exploit, and exploitation could result in elevated privileges or in significant data loss or downtime. Risk Score: 7.0 - 8.9
MEDIUM	Indicates there is a medium severity level vulnerability in the corresponding component. Vulnerabilities that score in the medium range usually have some of the following characteristics: • Vulnerabilities that require the attacker to manipulate individual victims via social engineering tactics. • Denial of service vulnerabilities that are difficult to set up. • Exploits that require an attacker to reside on the same local network as the victim. • Vulnerabilities where exploitation provides only very limited access. • Vulnerabilities that require user privileges for successful exploitation. Risk Score: 4.0 - 6.9
LOW	Indicates there is a low severity level vulnerability in the corresponding component. These are the ones that results can't be determined precisely and are caused by not applying the best practices. Risk Score: 0.1 - 3.9
INFO	Indicates there is an information disclosure in the corresponding component. They are reported simply for your information as a website owner, as they may not have a direct impact but could help an attacked to gain a better understanding of your underlying systems. Risk Score: 0.0



BP

The **Best Practice** severity level is for detected issues that are recommended practices but are not vulnerabilities and not as serious as Information Alerts. Depending on the Best Practice suggestions, impacts might include damage to the privacy of the user, detraction from a site's extra layers of security, or failure to meet with industry standards.

Risk Score: 0.0

After that, detected vulnerabilities detailed by their severities, their impacts on the system, the exploitation type, vulnerable components, description of vulnerability, remediation/solution methods and the references to learn more about the vulnerability.

We have leveraged the Common Vulnerability Scoring System, CVSS, v3 to estimate the severity rating and risk score of the identified vulnerabilities. The Common Vulnerability Scoring System (CVSS) is a free and open industry standard for assessing the severity of computer system security vulnerabilities. CVSS attempts to assign severity scores to vulnerabilities, allowing responders to prioritize responses and resources according to the threat. Scores are calculated based on a formula that depends on several metrics that approximate ease of exploit and the impact of exploit. Scores range from **0 to 10**, with 10 being the most severe.

Risk Scores:

The Base score group represents the intrinsic characteristics of a vulnerability that are constant over time and across user environments.

The Exploitability score reflects the ease and technical means by which the vulnerability can be exploited.

The Impact score reflects the direct consequence of a successful exploit and represents the consequence of the *thing that suffers the impact*. It measures the impact to the well-known CIA Triad (Confidentiality, Integrity, Availability) of the impacted system

The tests conducted are explained in the **Appendix** section.



5 FINDINGS

The security findings found as a result of the project were categorized according to the following main titles:

- API and Web Application Findings
- Microsoft Azure Infrastructure Findings
- External Servers/IPs/Domains Scan



5.1 API AND APPLICATIONS FINDINGS

The API and Desktop applications included in the scope have been tested according to OWASP's Security Testing Guide (WSTG). Alongside the OWASP Security testing guide, custom checks have been implemented for testing desktop and Revit plugins.



5.1.1 INSUFFICIENT ANTI-AUTOMATION

Affected Apps

- <https://staging.xyzreality.com/>*
- <https://cloud.xyzreality.com/>*
- <https://test.holosite.dev/>*

MEDIUM

Risk Information

RISK	
Risk Factor:	Medium
CVSS v3.0 Base Score:	5.8
CVSS v3.0 Vector:	AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:L/A:N
CVSS v3.0 Impact	1.4
CVSS v3.0 Exploitability	3.9

Description

Insufficient Anti-automation occurs when an application permits an attacker to automate a process that was originally designed to be performed only in a manual fashion, i.e. by a human web user.

Web application functionality that is often a target for automation attacks may include:

- Application login forms – attackers may automate brute force login requests in an attempt to guess user credentials
- Service registration forms – attackers may automatically create thousands of new accounts
- Email forms – attackers may exploit email forms as spam relays or for flooding a certain user's mailbox
- Account maintenance – attackers may perform mass DoS against an application, by flooding it with numerous requests to disable or delete user accounts
- Account information forms – attackers may perform mass attempts to harvest user personal information from a web application
- Comment forms / Content Submission forms – these may be used for spamming blogs, web forums and web bulletin boards by automatically submitting contents such as spam or even web-based malware
- Online polls - polls and other types of online voting systems can be automatically subverted in favour of a certain choice.



Details

This security finding appears to affect various modules of both API and applications.

In particular, it has been observed that there is no restriction on the number of files that can be uploaded to the application within a certain time period. In this case, it may cause structures such as disk space or databases where the application's data is stored may be out of service.

The screenshot below indicates that hundreds of tasks are created on the platform without any restrictions.



Request	Payload	Status	Error	Timeout	Length	Comment
100	null	201			2138	Contains a JWT
99	null	201			2137	Contains a JWT
98	null	201			2137	Contains a JWT
97	null	201			2137	Contains a JWT
96	null	201			2137	Contains a JWT
95	null	201			2137	Contains a JWT
94	null	201			2137	Contains a JWT
93	null	201			2137	Contains a JWT
92	null	201			2137	Contains a JWT

Request	Response
Pretty	Hex Render
1	HTTP/2 201 Created
2	Expires: 0
3	Cache-Control: no-cache, no-store, max-age=0, must-revalidate
4	Set-Cookie: XSRF-TOKEN=1edc329e-fb8d-4a08-b610-136fc5e4cd94; path=/; secure
5	X-Xss-Protection: 1; mode=block
6	Pragma: no-cache
7	Location: /api/issues/637cda057435ca6e0f50949b
8	Date: Tue, 22 Nov 2022 14:17:43 GMT
9	Strict-Transport-Security: max-age=31536000 ; includeSubDomains
10	X-Bpmapp-Alert: bpmApp.bpmIssue.created
11	X-Bpmapp-Params: 637cda057435ca6e0f50949b
12	Vary: Origin,Access-Control-Request-Method,Access-Control-Request-Headers,Origin,Access-Control-Request-Method,Access-Control-Request-Headers
13	X-Content-Type-Options: nosniff
14	Content-Type: application/json
15	X-Envoy-Upstream-Service-Time: 2348
16	Server: istio-envoy
17	
18	{ "id": "637cda057435ca6e0f50949b", "title": "Test-Issue-Title", "location": null, "locationDescription": "", "type": "Commissioning", "status": "OPEN", "description": "", "task": { "id": "637cda057435ca6e0f50949a", "title": "Test-Issue-Title", "type": null, "dueDate": "2022-11-25", "assignee": { "id": "6149c06c3b634f2d18966116", "firstName": "BÃkÃr", "lastName": "Emre", "name": "BÃkÃr Emre", "email": "emre@hackeracademy.uk", "company": { "id": "6149c06c3b634f2d18966115", "name": "Hacker Academy" } }, "assigneeId": "6149c06c3b634f2d18966116", "assigneeType": "CONTACT", "assigneeName": "BÃkÃr Emre" } }



☐ ☆ ➤ XYZ Reality	TestProject - Issue #100 was assigned to Bâkır Emre - Dear Bâkır, Bâkır Emre assigned this issue...	14:17
☐ ☆ ➤ XYZ Reality	TestProject - Issue #85 was assigned to Bâkır Emre - Dear Bâkır, Bâkır Emre assigned this issue t...	14:17
☐ ☆ ➤ XYZ Reality	TestProject - Issue #89 was assigned to Bâkır Emre - Dear Bâkır, Bâkır Emre assigned this issue t...	14:17
☐ ☆ ➤ XYZ Reality	TestProject - Issue #87 was assigned to Bâkır Emre - Dear Bâkır, Bâkır Emre assigned this issue t...	14:17
☐ ☆ ➤ XYZ Reality	TestProject - Issue #88 was assigned to Bâkır Emre - Dear Bâkır, Bâkır Emre assigned this issue t...	14:17
☐ ☆ ➤ XYZ Reality	TestProject - Issue #86 was assigned to Bâkır Emre - Dear Bâkır, Bâkır Emre assigned this issue t...	14:17
☐ ☆ ➤ XYZ Reality	TestProject - Issue #79 was assigned to Bâkır Emre - Dear Bâkır, Bâkır Emre assigned this issue t...	14:17
☐ ☆ ➤ XYZ Reality	TestProject - Issue #75 was assigned to Bâkır Emre - Dear Bâkır, Bâkır Emre assigned this issue t...	14:17
☐ ☆ ➤ XYZ Reality	TestProject - Issue #66 was assigned to Bâkır Emre - Dear Bâkır, Bâkır Emre assigned this issue t...	14:17
☐ ☆ ➤ XYZ Reality	TestProject - Issue #65 was assigned to Bâkır Emre - Dear Bâkır, Bâkır Emre assigned this issue t...	14:17
☐ ☆ ➤ XYZ Reality	TestProject - Issue #56 was assigned to Bâkır Emre - Dear Bâkır, Bâkır Emre assigned this issue t...	14:17
☐ ☆ ➤ XYZ Reality	TestProject - Issue #55 was assigned to Bâkır Emre - Dear Bâkır, Bâkır Emre assigned this issue t...	14:17
☐ ☆ ➤ XYZ Reality	TestProject - Issue #53 was assigned to Bâkır Emre - Dear Bâkır, Bâkır Emre assigned this issue t...	14:17
☐ ☆ ➤ XYZ Reality	TestProject - Issue #51 was assigned to Bâkır Emre - Dear Bâkır, Bâkır Emre assigned this issue t...	14:17
☐ ☆ ➤ XYZ Reality	TestProject - Issue #47 was assigned to Bâkır Emre - Dear Bâkır, Bâkır Emre assigned this issue t...	14:17
☐ ☆ ➤ XYZ Reality	TestProject - Issue #48 was assigned to Bâkır Emre - Dear Bâkır, Bâkır Emre assigned this issue t...	14:17
☐ ☆ ➤ XYZ Reality	TestProject - Issue #38 was assigned to Bâkır Emre - Dear Bâkır, Bâkır Emre assigned this issue t...	14:17
☐ ☆ ➤ XYZ Reality	TestProject - Issue #34 was assigned to Bâkır Emre - Dear Bâkır, Bâkır Emre assigned this issue t...	14:17
☐ ☆ ➤ XYZ Reality	TestProject - Issue #23 was assigned to Bâkır Emre - Dear Bâkır, Bâkır Emre assigned this issue t...	14:17

Assigning over 100 tasks to a registered user on the system.



Impact

- Attackers may perform mass DoS against an application, by flooding with numerous requests. They can create hundreds of mess records which may cause missing important records.
- With automated file upload, it's possible to consume available disk space of the application server or the database server, which is another way of a DoS (denial of service) attack.

Recommendations

- Provide configurable per-user/session request rate limits. For authenticated transactions, limits should be configurable on a per-user or per-session basis. Configuration should allow combining multiple limits of the form "# of requests per time period". For example, an administrator should be allowed to combine "10 requests per minute" with "500 requests per day" in order to simultaneously apply policies which prevent users from automatic crawling/screen scraping as well as longer-term slow leeching activities.
- A common practice for protecting against automation attacks is the implementation of CAPTCHA mechanisms in web applications. CAPTCHA stands for "Completely Automated Public Turing test to Tell Computers and Humans Apart".
- Perimeter technologies including geocaching/proxy services must support automatic and/or manual "panic button" anti-automation, enforcing progressive CAPTCHA for unvalidated requests, triggering on excessive 5XX responses, or direct signal from the application.
- Provide a common configuration functionality available to any feature/function. Configuration settings should allow multiple per-user rate limits as well as global rate limits to prevent denial of service.

References

- OWASP Periodic Table of Vulnerabilities - Brute Force (Generic) / Insufficient Anti-automation - [https://wiki.owasp.org/index.php/OWASP_Periodic_Table_of_Vulnerabilities_-_Brute_Force_\(Generic\)_/_Insufficient_Anti-automation](https://wiki.owasp.org/index.php/OWASP_Periodic_Table_of_Vulnerabilities_-_Brute_Force_(Generic)_/_Insufficient_Anti-automation)
- Insufficient Anti-automation - https://projects.webappsec.org/w/page/13246938/Insufficient_Anti-automation
- Blocking Brute Force Attacks - https://www.owasp.org/index.php/Blocking_Brute_Force_Attacks



5.1.2 BROKEN ACCESS CONTROL

Affected Apps

- <https://staging.xyzreality.com/>*
- <https://cloud.xyzreality.com/>*
- <https://test.holosite.dev/>*

MEDIUM

Risk Information

RISK	
Risk Factor:	Medium
CVSS v3.0 Base Score:	5.8
CVSS v3.0 Vector:	AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:L/A:N
CVSS v3.0 Impact	1.4
CVSS v3.0 Exploitability	3.9

Description

Access control enforces policy such that users cannot act outside of their intended permissions. Failures typically lead to unauthorized information disclosure, modification, or destruction of all data, or performing a business function outside of the limits of the use.

Bypassing access control checks by modifying the URL, internal application state, or the HTML page, or simply using a custom API attack tool.

Insecure Direct Object References (IDOR) occur when an application provides direct access to objects based on user-supplied input. As a result of this vulnerability attackers can bypass authorization and access resources in the system directly, for example database records or files. Insecure Direct Object References allow attackers to bypass authorization and access resources directly by modifying the value of a parameter used to directly point to an object. Such resources can be database entries belonging to other users, files in the system, and more. This is caused by the fact that the application takes user supplied input and uses it to retrieve an object without performing sufficient authorization checks. The best way to find out if an application is vulnerable to insecure direct object references is to verify that all object references have appropriate defences. To achieve this, consider:



For direct references to restricted resources, does the application fail to verify the user is authorized to access the exact resource they have requested?

If the reference is an indirect reference, does the mapping to the direct reference fail to limit the values to those authorized for the current user?

Code review of the application can quickly verify whether either approach is implemented safely. Testing is also effective for identifying direct object references and whether they are safe. Automated tools typically do not look for such flaws because they cannot recognize what requires protection or what is safe or unsafe.

Details

This security finding appears to affect various modules of both API and applications.

In particular, it has been observed that there is no restriction on the number of files that can be uploaded to the application within a certain time period. In this case, it may cause structures such as disk space or databases where the application's data is stored may be out of service.

The screenshots below show that information belonging to other companies can be accessed on the platform without any restrictions.



```

HTTP/2 200 OK
Expires: 0
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Set-Cookie: XSRF-TOKEN=497a24bc-c05d-4d96-8025-cf88fbdf0d83; path=/; secure
X-Xss-Protection: 1; mode=block
Pragma: no-cache
Date: Tue, 20 Dec 2022 07:50:24 GMT
X-Total-Count: 20
Vary:
Origin, Access-Control-Request-Method, Access-Control-Request-Headers, Origin, Access-Control-Request-Method, Access-Control-Request-Headers
Strict-Transport-Security: max-age=31536000 ; includeSubDomains
X-Content-Type-Options: nosniff
Content-Type: application/json
Link: <https://cloud.xyzreality.com/api/companies/?page=0&size=20>; rel="last", <https://cloud.xyzreality.com/api/companies/?page=0&size=20>; rel="first"
X-Envoy-Upstream-Service-Time: 157
Server: istio-envoy

[
  {
    "id": "5f96e2fb55340c692b14895b",
    "name": "XYZ Reality",
    "description": null,
    "domain": "xyzreality.com",
    "address1": "338-346 Goswell Road",
    "address2": "Angel",
    "city": "London",
    "country": null,

    "id": "5fac1c9bfa6ca82e71e5b3e8",
    "name": "Laing O'Rourke",
    "description": null,
    "domain": "laingorourke.com",
    "address1": "123 Avenue",
    "address2": null,
    "city": "London",
    "country": null,
    "country": "United Kingdom",
    "postcode": "SE13AA",
    "businessPhone": null,
    "status": true,
    "logo": null,
    "logoContentType": null,
    "ownTenant": {
      "id": "620fb069060eac3c982527a0",
      "name": "Laing O'Rourke",
      "domain": "laingorourke.com",
      "twoFactorEnabled": false
    },
    "primaryContact": null
  }
]

```



Company Domains
autodesk.com
dornangroup.com
equinix.com
eu.equinix.com
givmail.com
hackeracademy.uk
izigo.co.uk
joneseng.com
laingorourke.com
macegroup.com
merck.com
metimurcad.com
pmgroup-global.com
teamjonesplc.com
vomoto.com
webuildgroup.com
xyzreality-prod-test.com
xyzreality.com
zetmail.com

Access to information of other companies registered on the XYZ Reality Cloud portal.



Impact

- Unauthorized access to sensitive data – Object references often include database IDs, which attackers can access to expose sensitive information about the application/users. The unauthorized user can also use database entries to prepare malicious SQL payloads for further attacks.
- Object manipulation – With access to internal references, attackers gain direct access to the data and state of the application. Attackers can then manipulate the exposed objects to modify data, access hidden functions, or further escalate privileges.
- Direct file access – Malicious users can combine IDOR attacks with directory transversal attack techniques to manipulate the host's file system. This grants them the ability to upload/download files freely and manipulate content accessed by other users.

Recommendations

- Preventing insecure direct object references requires selecting an approach for protecting each user accessible object (e.g., object number, filename):
- Use per user or session indirect object references. This prevents attackers from directly targeting unauthorized resources. For example, instead of using the resource's database key, a drop-down list of six resources authorized for the current user could use the numbers 1 to 6 to indicate which value the user selected. The application has to map the per-user indirect reference back to the actual database key on the server. OWASP's ESAPI includes both sequential and random-access reference maps that developers can use to eliminate direct object references.
- Check access. Each use of a direct object reference from an untrusted source must include an access control check to ensure the user is authorized for the requested object.

References

- Top 10 2013-A4-Insecure Direct Object References - https://wiki.owasp.org/index.php/Top_10_2013-A4-Insecure_Direct_Object_References
- Testing for Insecure Direct Object References - https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/05-Authorization_Testing/04-Testing_for_Insecure_Direct_Object_References
- Insecure Direct Object Reference Prevention Cheat Sheet - https://cheatsheetseries.owasp.org/cheatsheets/Insecure_Direct_Object_Reference_Prevention_Cheat_Sheet.html



5.1.3 TLS VERSION 1. AND 1.1 PROTOCOL DETECTION

Affected Apps

- <https://staging.xyzreality.com/>*
- <https://cloud.xyzreality.com/>*
- <https://test.holosite.dev/>*

MEDIUM

Risk Information

RISK	
Risk Factor:	Medium
CVSS v3.0 Base Score:	4.8
CVSS v3.0 Vector:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N
CVSS v3.0 Impact	2.5
CVSS v3.0 Exploitability	2.2

Description

The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible.

As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits. The screenshots below show that information belonging to other companies can be accessed on the platform without any restrictions.

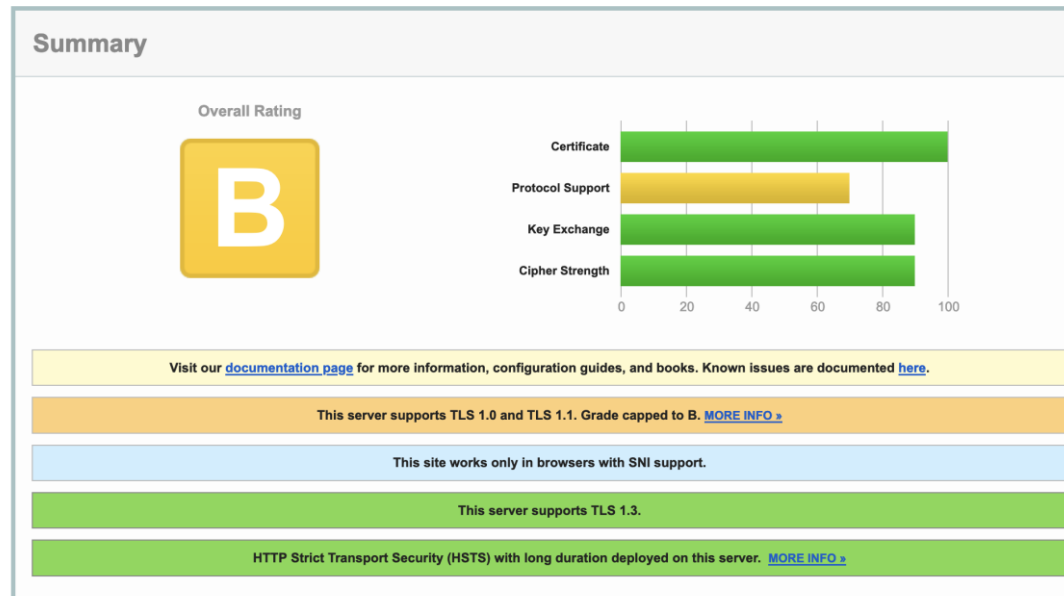
The remote service accepts connections encrypted using TLS 1.1. TLS 1.1 lacks support for current and recommended cipher suites. Ciphers that support encryption before MAC computation, and authenticated encryption modes such as GCM cannot be used with TLS 1.1



As of March 31, 2020, Endpoints that are not enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

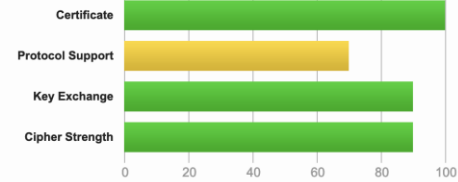
You are here: [Home](#) > [Projects](#) > [SSL Server Test](#) > [pages.xyzreality.com](#) > 199.60.103.28

SSL Report: [pages.xyzreality.com](#) (199.60.103.28)



**SSL Report: cloud.xyzreality.com (20.23.237.227)**Assessed on: Tue, 20 Dec 2022 08:45:11 UTC | **HIDDEN** | [Clear cache](#)[Scan Another »](#)**Summary**

Overall Rating

Visit our [documentation page](#) for more information, configuration guides, and books. Known issues are documented [here](#).This server supports TLS 1.0 and TLS 1.1. Grade capped to B. [MORE INFO »](#)

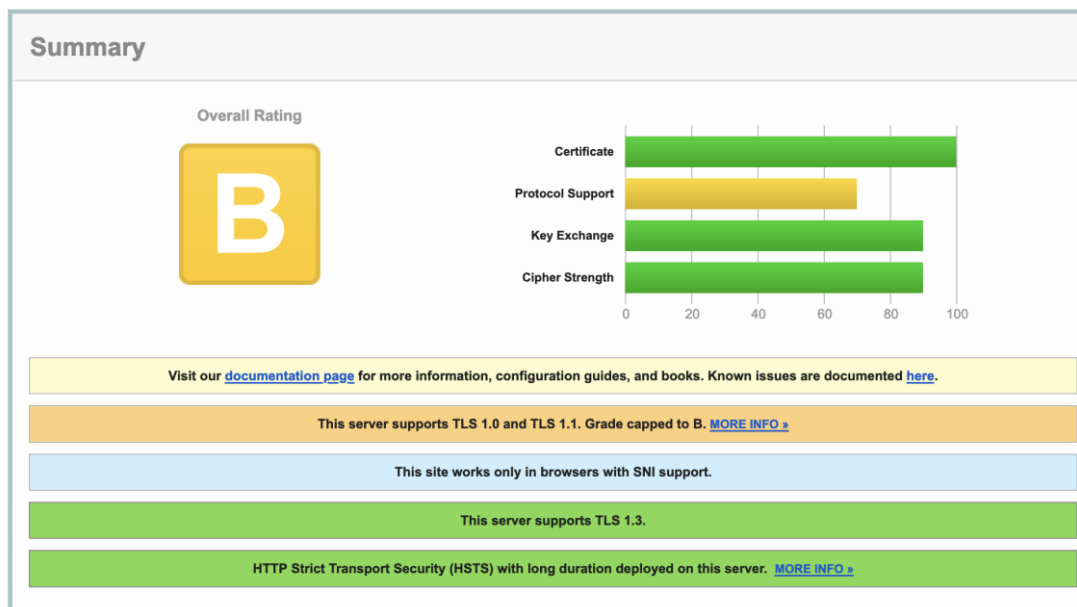
This site works only in browsers with SNI support.

This server supports TLS 1.3.

HTTP Strict Transport Security (HSTS) with long duration deployed on this server. [MORE INFO »](#)



SSL Report: www.xyzreality.com (199.60.103.28)





DOMAINS
dev.holosite.dev
frontend.holosite.dev
jenkins-staging.holosite.dev
cloud.xyzreality.com
pages.xyzreality.com
www.xyzreality.com
xyzreality.com



Company Domains
autodesk.com
dornangroup.com
equinix.com
eu.equinix.com
givmail.com
hackeracademy.uk
izigo.co.uk
joneseng.com
laingorourke.com
macegroup.com
merck.com
metimurcad.com
pmgroup-global.com
teamjonesplc.com
vomoto.com
webuildgroup.com
xyzreality-prod-test.com
xyzreality.com
zetmail.com

Access to information of other companies registered on the XYZ Reality Cloud portal.



Impact

- Unauthorized access to sensitive data – Object references often include database IDs, which attackers can access to expose sensitive information about the application/users. The unauthorized user can also use database entries to prepare malicious SQL payloads for further attacks.
- Object manipulation – With access to internal references, attackers gain direct access to the data and state of the application. Attackers can then manipulate the exposed objects to modify data, access hidden functions, or further escalate privileges.
- Direct file access – Malicious users can combine IDOR attacks with directory transversal attack techniques to manipulate the host's file system. This grants them the ability to upload/download files freely and manipulate content accessed by other users.

Recommendations

- Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

References

- Deprecating TLSv1.0 and TLSv1.1 - <https://datatracker.ietf.org/doc/html/draft-ietf-tls-oldversions-deprecate-00>



5.2 AZURE CLOUD SECURITY CONTROLS

All CIS Benchmarks focus on technical configuration settings used to maintain and/or increase the security of the addressed technology, and they should be used in conjunction with other essential cyber hygiene tasks like:

- Monitoring the base operating system for vulnerabilities and quickly updating with the latest security patches
- Monitoring applications and libraries for vulnerabilities and quickly updating with the latest security patches

In the end, the CIS Benchmarks are designed as a key component of a comprehensive cybersecurity program.

This document, CIS Microsoft Azure Foundations Benchmark, provides prescriptive guidance for establishing a secure baseline configuration for Microsoft Azure. The scope of this benchmark is to establish the foundation level of security for anyone adopting Microsoft Azure Cloud. The benchmark is, however, not an exhaustive list of all possible security configurations and architecture. The benchmark should be understood as a starting point. Site-specific tailoring will almost certainly be required.

Multiple Methods of Audit and Remediation

Throughout the Benchmark, Audit and Remediation procedures are prescribed using up to four different methods. These multiple methods are presented for the convenience of readers who will be coming from different technical and experiential backgrounds. To perform any given Audit or Remediation, only one method needs to be performed. Not every method is available for every recommendation, and many that are available are not yet written for every recommendation. The methods presented in the Benchmark are formatted and titled as follows:

- "From Azure Portal" - This is the administrative GUI accessed at <https://portal.azure.com>.
- "From Azure CLI" - See additional detail in the next section.
- "From PowerShell" - See additional detail in the next section.
- "From REST API" - An Application Programming Interface (API) for HTTP operations on service endpoints.



5.2.1 IDENTITY AND ACCESS MANAGEMENT

This section covers security recommendations to set identity and access management policies on an Azure Subscription. Identity and Access Management policies are the first step towards a defence-in-depth approach to securing an Azure Cloud Platform environment.

Many of the recommendations from this section are marked as "Manual" while Azure CLI and PowerShell are being improved to support and perform the respective audits and remediation. From a security posture standpoint, these recommendations are still very important and should not be discounted because they are "Manual." As automation capability using Rest API is developed for this Benchmark, the related recommendations will be updated with the respective audit and remediation steps and changed to an "automated" assessment status.

If any problems are encountered running Azure CLI or PowerShell methodologies, please refer to the Overview for this benchmark where you will find additional detail on permission and required cmdlets

5.2.1.1 CONTROL: 1.4 ENSURE GUEST USERS ARE REVIEWED ON A REGULAR BASIS

Azure AD is extended to include Azure AD B2B collaboration, allowing you to invite people from outside your organization to be guest users in your cloud account and sign in with their own work, school, or social identities. Guest users allow you to share your company's applications and services with users from any other organization, while maintaining control over your own corporate data. Work with external partners, large or small, even if they don't have Azure AD or an IT department. A simple invitation and redemption process lets partners use their own credentials to access your company's resources as a guest user. Guest users in every subscription should be review on a regular basis to ensure that inactive and unneeded accounts are removed

Before removing guest users, determine their use and scope. Like removing any user, there may be unforeseen consequences to systems if it is deleted.

Remediation: From Azure Portal

1. From Azure Home select the Portal Menu
2. Select Azure Active Directory
3. Then Users and group
4. Select All Users
5. Click on Add filters button, select User type, click Apply, select Guest, click Apply



6. Delete all Guest users that are no longer required or are inactive.

From Azure CLI

Before deleting the user, set it to inactive using the ID from the Audit Procedure to determine if there are any dependent systems.

```
az ad user update --id <exampleaccountid@domain.com> --account-enabled {false}
```

After determining that there are no dependent systems delete the user.

```
Remove-AzureADUser -ObjectId <exampleaccountid@domain.com>
```

From Azure Powershell

Before deleting the user, set it to inactive using the ID from the Audit Procedure to determine if there are any dependent systems.

```
Set-AzureADUser -ObjectId "<exampleaccountid@domain.com>" -AccountEnabled false
```

After determining that there are no dependent systems delete the user.

```
PS C:\>Remove-AzureADUser -ObjectId <exampleaccountid@domain.com>
```

pietro.desiato_xyzreality.com#EXT#@xyzreality.onmicrosoft.com

Information

Principal Name: pietro.desiato_xyzreality.com#EXT#@xyzreality.onmicrosoft.com
Display Name: Pietro Desiato
Given Name: None
Surname: None
Mail Nickname: pietro.desiato_xyzreality.com#EXT#
Mail: pietro.desiato@xyzreality.com
Sign-In Names: None
Type: Guest
Status: Enabled
Usage Location: None
Deletion Timestamp: None

Roles

0

Groups

0



it_xyzreality.com#EXT#@xyzreality.onmicrosoft.com

Information

Principal Name: it_xyzreality.com#EXT#@xyzreality.onmicrosoft.com
Display Name: IT XYZ Reality
Given Name: None
Surname: None
Mail Nickname: it_xyzreality.com#EXT#
Mail: it@xyzreality.com
Sign-In Names: None
Type: Guest
Status: Enabled
Usage Location: None
Deletion Timestamp: None

Roles

0

Groups

0



tolga.ingenc_xyzreality.com#EXT#@xyzreality.onmicrosoft.com

Information

Principal Name: tolga.ingenc_xyzreality.com#EXT#@xyzreality.onmicrosoft.com
Display Name: Tolga Ingenc
Given Name: None
Surname: Ingenc
Mail Nickname: tolga.ingenc_xyzreality.com#EXT#
Mail: tolga.ingenc@xyzreality.com
Sign-In Names: None
Type: Guest
Status: Enabled
Usage Location: None
Deletion Timestamp: None

Roles

3

- Owner (subscription c75fed9d-9b73-4771-b64d-175bab58d352)
- Owner (subscription c75fed9d-9b73-4771-b64d-175bab58d352)
- Owner (subscription 7ab0219b-21c4-46ec-9b8a-46ed3cd8dbf0)

Groups

0



accounts_xyzreality.com#EXT#@xyzreality.onmicrosoft.com

Information

Principal Name: accounts_xyzreality.com#EXT#@xyzreality.onmicrosoft.com
Display Name: Xyz Reality Account
Given Name: None
Surname: Account
Mail Nickname: accounts_xyzreality.com#EXT#
Mail: accounts@xyzreality.com
Sign-In Names: None
Type: **Guest**
Status: Enabled
Usage Location: None
Deletion Timestamp: None

Roles

0

Groups

0

atinc.erguven_xyzreality.com#EXT#@xyzreality.onmicrosoft.com

Information

Principal Name: atinc.erguven_xyzreality.com#EXT#@xyzreality.onmicrosoft.com
Display Name: Atinc Erguven
Given Name: None
Surname: None
Mail Nickname: atinc.erguven_xyzreality.com#EXT#
Mail: atinc.erguven@xyzreality.com
Sign-In Names: None
Type: **Guest**
Status: Enabled
Usage Location: None
Deletion Timestamp: None

Roles

0

Groups

0



5.2.1.2 CONTROL: 1.17 ENSURE THAT USERS CAN CREATE SECURITY GROUPS IN AZURE PORTALS, API OR POWERSHELL' IS SET TO 'NO'

Restrict security group creation to administrators only.

When creating security groups is enabled, all users in the directory are allowed to create new security groups and add members to those groups. Unless a business requires this day-to-day delegation, security group creation should be restricted to administrators only.

Authorization Policy

Information

Name: Authorization Policy

Allow Invites From: everyone

Allowed To Create Apps: Enabled

Allowed To Create Security Groups: **Enabled**

Allowed To Read Other Users: Enabled

Allow Email Verified Users To Join Organization: Disabled

From Azure Portal

- From Azure Home select the Portal Menu
- Select Azure Active Directory
- Then Groups
- Select General in setting



- Set Users can create security groups in Azure portals, API or PowerShell to **No**

Please note that at this point of time, there is no Azure CLI or other API commands available to programmatically conduct security configuration for this recommendation

Default Value

By default, Users can create security groups in Azure portals, API or PowerShell is set to Yes.



5.2.1.3 MANAGED IDENTITY SHOULD BE USED IN FUNCTION APPS

For enhanced authentication security, use a managed identity.

On Azure, managed identities eliminate the need for developers to have to manage credentials by providing an identity for the Azure resource in Azure AD and using it to obtain Azure Active Directory (Azure AD) tokens.

Remediation: From Azure Portal

To create a managed identity for your function app:

1. Go to the App Service for your API app
2. Navigate to Platform features
3. Select Identity
4. Use System assigned or User assigned identity following the steps described in this doc: <https://aka.ms/managed-identity>

Name	↑↓ Subscription
 jobtriggerapp	subs-xyz-hsc-nonprod

5.2.1.4 A MAXIMUM OF 3 OWNERS SHOULD BE DESIGNATED FOR SUBSCRIPTIONS

To reduce the potential for breaches by compromised owner accounts, we recommend limiting the number of owner accounts to a maximum of 3

Remediation: From Azure Portal

To remove owner permissions from user accounts on your subscription:

Click a subscription from the list of subscriptions below or click 'Take action' if you are coming from a specific subscription.

The Access control (IAM) page opens.

1. Click the Role assignments tab and set the 'Role' filter to 'Owner'.
2. Select the owners you want to remove.
3. Click Remove.



Name	↑↓	Subscription
 c75fed9d-9b73-4771-b64d-175bab58d352		subs-xyz-hsc-nonprod
 7ab0219b-21c4-46ec-9b8a-46ed3cd8dbf0		subs-xyz-hsc-prod

5.2.1.5 GUEST ACCOUNTS WITH OWNER PERMISSIONS ON AZURE RESOURCES SHOULD BE REMOVED

Accounts with owner permissions that have been provisioned outside of the Azure Active Directory tenant (different domain names), should be removed from your Azure resources.

Guest accounts are not managed to the same standards as enterprise tenant identities.

These accounts can be targets for attackers looking to find ways to access your data without being noticed.

Remediation: From Azure Portal

Review the list of guest accounts that require access removal on the Accounts section. Click on each account to view its role definitions and locate source scope. If you accept the risk for a specific account, use the exempt capability to exclude it from evaluation.

1. Go to the Azure portal.
2. Open Access control (IAM) at a scope, such as management group, subscription, resource group, or resource, where the guest user has a role assignment.
3. Click the Role assignments tab to view all the role assignments.
4. In the list of role assignments, add a checkmark next to the guest user with the role assignment you want to remove.
5. Click Remove. In the remove role assignment message that appears, click Yes.

Name	Email	Account ID
Tolga Ingenc	tolga.ingenc@xyzreality.com	99c12171-c47d-425d-8415-eb0a1d4b9081



5.2.2 STORAGE ACCOUNTS

This section covers security recommendations to follow to set storage account policies on an Azure Subscription. An Azure storage account provides a unique namespace to store and access Azure Storage data objects

5.2.2.1 STORAGE ACCOUNT SHOULD USE A PRIVATE LINK CONNECTION

Private links enforce secure communication, by providing private connectivity to the storage account

Remediation: From Azure Portal

To enforce secure communications for your storage accounts, add a private endpoint as described here:

<https://aka.ms/connectprivatelytostorageaccount>.

Name	↑↓	Subscription
 ts4104westeuropestaging		subs-xyz-hsc-nonprod
 ts4104westeuropedev		subs-xyz-hsc-nonprod
 ts4104eastusstaging		subs-xyz-hsc-nonprod
 ts16aewesteuropeprod		subs-xyz-hsc-prod
 sthscstaging		subs-xyz-hsc-nonprod
 sthscprod		subs-xyz-hsc-prod
 sthscdevfnc		subs-xyz-hsc-nonprod
 sthscdev		subs-xyz-hsc-nonprod
 stghcdevcost		subs-xyz-hsc-nonprod
 rghscdevfunctionsbf4d		subs-xyz-hsc-nonprod
 rghscdevfunctionsbdbbe		subs-xyz-hsc-nonprod
 jobschedulersa		subs-xyz-hsc-nonprod
 cswesteuropa10032001ece1		subs-xyz-hsc-nonprod
 csb10032001ece07b33		subs-xyz-hsc-nonprod



5.2.2.2 STORAGE ACCOUNTS SHOULD RESTRICT NETWORK ACCESS USING VIRTUAL NETWORK RULES

Protect your storage accounts from potential threats using virtual network rules as a preferred method instead of IP-based filtering. Disabling IP-based filtering prevents public IPs from accessing your storage accounts.

Remediation: From Azure Portal

To protect your storage account from potential threats using virtual network rules:

1. In the Azure portal, open your storage account.
2. From the left sidebar, select 'Networking'.
3. From the 'Allow access from' section, select 'Selected networks'.
4. Add a Virtual network under the 'Virtual networks' section. Do not add allowed IP ranges/ or addresses in the firewall. This is to prevent public IPs from accessing your storage account. For details, see: <https://aka.ms/storagenetworksecurity>.



Name	↑↓	Subscription
 ts4104westeuropestaging		subs-xyz-hsc-nonprod
 ts4104westeuropedev		subs-xyz-hsc-nonprod
 ts4104eastusstaging		subs-xyz-hsc-nonprod
 ts16aewesteuropeprod		subs-xyz-hsc-prod
 sthscstaging		subs-xyz-hsc-nonprod
 sthscprod		subs-xyz-hsc-prod
 sthscdevfnc		subs-xyz-hsc-nonprod
 sthscdev		subs-xyz-hsc-nonprod
 stghcdevcost		subs-xyz-hsc-nonprod
 rghscdevfunctionsbf4d		subs-xyz-hsc-nonprod
 rghscdevfunctionsbdbe		subs-xyz-hsc-nonprod
 jobschedulersa		subs-xyz-hsc-nonprod
 cswesteurope10032001ece1		subs-xyz-hsc-nonprod
 csb10032001ece07b33		subs-xyz-hsc-nonprod

5.2.2.3 STORAGE ACCOUNT PUBLIC ACCESS SHOULD BE DISALLOWED

Anonymous public read access to containers and blobs in Azure Storage is a convenient way to share data, but might present security risks. To prevent data breaches caused by undesired anonymous access, Microsoft recommends preventing public access to a storage account unless your scenario requires it.

Remediation: From Azure Portal

Quick fix:

Select the unhealthy resources and click “Fix” to launch “Quick fix” remediation. [Learn more >](#)

Note: After the process completes, it may take up to 30 min until your resources move to the ‘healthy resources’ tab.



Manual remediation:

To prevent public access to containers and blobs in your storage account:

1. In the Azure portal, navigate to your storage account.
2. From the settings menu, select "Configuration".
3. Set "Allow Blob public access" to "Disabled".

Learn more about public access

Note: It might take several minutes after remediation completes until the resource appears in the 'healthy resources' tab.

Name	↑↓	Subscription
 ts4104westeuropedev		subs-xyz-hsc-nonprod
 ts16aewesteuropesprod		subs-xyz-hsc-prod
 sthscstaging		subs-xyz-hsc-nonprod
 sthscprod		subs-xyz-hsc-prod
 sthscdevfnc		subs-xyz-hsc-nonprod
 sthscdev		subs-xyz-hsc-nonprod
 stghcdevcost		subs-xyz-hsc-nonprod
 rghscdevfunctionsbf4d		subs-xyz-hsc-nonprod
 rghscdevfunctionsbdbe		subs-xyz-hsc-nonprod
 jobschedulersa		subs-xyz-hsc-nonprod
 cswesteuropa10032001ece1		subs-xyz-hsc-nonprod

5.2.2.4 STORAGE ACCOUNT PUBLIC ACCESS SHOULD BE DISALLOWED

Key vault's firewall prevents unauthorized traffic from reaching your key vault and provides an additional layer of protection for your secrets. Enable the firewall to make sure that only traffic from allowed networks can access your key vault.

Remediation: From Azure Portal

:

To enable the key vault firewall:



1. In the Azure portal, open your key vault.
2. From the left sidebar, select Networking (located under the "Settings" section).
3. Set the radio button to Private endpoint and selected networks and select Save.

Name	↑↓	Subscription
 kv-xyz-hsc-staging-admin		subs-xyz-hsc-nonprod
 kv-xyz-hsc-staging		subs-xyz-hsc-nonprod
 kv-xyz-hsc-prod-admin		subs-xyz-hsc-prod
 kv-xyz-hsc-prod		subs-xyz-hsc-prod
 kv-xyz-hsc-dev-admin		subs-xyz-hsc-nonprod
 kv-xyz-hsc-dev		subs-xyz-hsc-nonprod

5.2.3 DATABASE SERVICES

This section covers security recommendations to follow to set general database services policies on an Azure Subscription. Subsections will address specific database types.

5.2.4 LOGGING AND MONITORING

This section covers security recommendations to follow to set logging and monitoring policies on an Azure Subscription

5.2.4.1 LOG ANALYTICS AGENT SHOULD BE INSTALLED ON VIRTUAL MACHINES

Defender for Cloud collects data from your Azure virtual machines (VMs) to monitor for security vulnerabilities and threats. Data is collected using the Log Analytics agent, formerly known as the Microsoft Monitoring Agent (MMA), which reads various security-related configurations and event logs from the machine and copies the data to your Log Analytics workspace for analysis. This agent is also required if your VMs are



used by an Azure managed service such as Azure Kubernetes Service or Azure Service Fabric. We recommend configuring auto-provisioning to automatically deploy the agent. If you choose not to use auto-provisioning, manually deploy the agent to your VMs using the instructions in the remediation steps.

Remediation: From Azure Portal

Select the unhealthy resources and click “Fix” to launch “Quick fix” remediation. Learn more >

Note: After the process completes, it may take up to 24 hours until your resources move to the ‘healthy resources’ tab.

Manual remediation:

For multiple ways to install and configure your Log Analytics agent see the following instructions. https://learn.microsoft.com/en-gb/azure/azure-monitor/agents/log-analytics-agent?WT.mc_id=Portal-Microsoft Azure_Security#installation-and-configuration

Name	↑↓	Subscription
 webgl01		subs-xyz-hsc-nonprod
 webgl-windows		subs-xyz-hsc-nonprod
 vm-hsc-staging-jenkins		subs-xyz-hsc-nonprod
 vm-hsc-prod-jenkins		subs-xyz-hsc-prod
 vm-hsc-converter		subs-xyz-hsc-nonprod
 test-01		subs-xyz-hsc-nonprod
 powerbi		subs-xyz-hsc-nonprod

5.2.4.2 AUTO PROVISIONING OF THE LOG ANALYTICS AGENT SHOULD BE ENABLED ON SUBSCRIPTIONS

To monitor for security vulnerabilities and threats, Microsoft Defender for Cloud collects data from your Azure virtual machines. Data is collected by the Log Analytics agent, formerly known as the Microsoft Monitoring Agent (MMA), which reads various security-related configurations and event logs from the machine and copies the data to your Log Analytics workspace for analysis. We recommend enabling auto provisioning to automatically deploy the agent to all supported Azure VMs and any new ones that are created.



Remediation: From Azure Portal

To configure auto provisioning:

1. From Defender for Cloud's Environment settings page, select the relevant subscription.
2. Open the Auto provisioning page and set the toggle to On for the Log Analytics agent.
3. Select the workspace to receive the data from the machines.

Learn more in [Configure auto provisioning for agents and extensions from Microsoft Defender for Cloud](#)

Name	↑↓	Subscription
 c75fed9d-9b73-4771-b64d-175bab58d352		subs-xyz-hsc-nonprod
 7ab0219b-21c4-46ec-9b8a-46ed3cd8dbf0		subs-xyz-hsc-prod

5.2.5 NETWORKING

This section covers security recommendations to follow in order to set networking policies on an Azure subscription.

5.2.5.1 ADAPTIVE NETWORK HARDENING RECOMMENDATIONS SHOULD BE APPLIED ON INTERNET FACING VIRTUAL

Defender for Cloud has analyzed the internet traffic communication patterns of the virtual machines listed below, and determined that the existing rules in the NSGs associated to them are overly-permissive, resulting in an increased potential attack surface.

This typically occurs when this IP address doesn't communicate regularly with this resource. Alternatively, the IP address has been flagged as malicious by Defender for Cloud's threat intelligence sources. Learn more in [Improve your network security posture with adaptive network hardening](#).

Remediation: From Azure Portal

To review the recommended changes to the traffic rules for your network security groups, select a machine or select 'Take action'



Name	↑↓	Subscription
 webgl01		subs-xyz-hsc-nonprod
 webgl-windows		subs-xyz-hsc-nonprod
 vm-hsc-staging-jenkins		subs-xyz-hsc-nonprod
 vm-hsc-prod-jenkins		subs-xyz-hsc-prod
 vm-hsc-dev-jenkins		subs-xyz-hsc-nonprod
 vm-hsc-converter		subs-xyz-hsc-nonprod
 test-01		subs-xyz-hsc-nonprod

5.2.5.2 ADAPTIVE NETWORK HARDENING RECOMMENDATIONS SHOULD BE APPLIED ON INTERNET FACING VIRTUAL MACHINES

Defender for Cloud has analysed the internet traffic communication patterns of the virtual machines listed below, and determined that the existing rules in the NSGs associated to them are overly-permissive, resulting in an increased potential attack surface.

This typically occurs when this IP address doesn't communicate regularly with this resource. Alternatively, the IP address has been flagged as malicious by Defender for Cloud's threat intelligence sources. Learn more in [Improve your network security posture with adaptive network hardening](#).

Remediation: From Azure Portal

To review the recommended changes to the traffic rules for your network security groups, select a machine or select 'Take action'



Name	↑↓	Subscription
 webgl01		subs-xyz-hsc-nonprod
 webgl-windows		subs-xyz-hsc-nonprod
 vm-hsc-staging-jenkins		subs-xyz-hsc-nonprod
 vm-hsc-prod-jenkins		subs-xyz-hsc-prod
 vm-hsc-dev-jenkins		subs-xyz-hsc-nonprod
 vm-hsc-converter		subs-xyz-hsc-nonprod
 test-01		subs-xyz-hsc-nonprod

5.2.5.3 ALL NETWORK PORTS SHOULD BE RESTRICTED ON NETWORK SECURITY GROUPS ASSOCIATED TO YOUR VIRTUAL MACHINE

Defender for Cloud has identified some of your network security groups' inbound rules to be too permissive. Inbound rules should not allow access from 'Any' or 'Internet' ranges. This can potentially enable attackers to target your resources.



aks-agentpool-17585647-nsg

Information

Name: aks-agentpool-17585647-nsg
Location: westeurope
State: Succeeded
Tags: Application:Azure Kubernetes Platform Billing Identifier:Technology Services
Environment:dev Environment Identifier:DEV Environment Version:Private Beta
Function:Tech Services Persistence:True Project Identifier:Kubernetes
Service Name:Kubernetes Service Owner:Holosite Cloud Service Type:External
Service Window:24x7
Resource group: rg-nodepool-dev

Inbound Security Rules

Priority	Name	Protocol	Source Port	Source Filter	Destination Port	Destination Filter
100	AllIncomingTCP	TCP	*	*	*	*
500	a1929606d68b24e5a97b71ff1ee27abf-TCP-15021-Internet	Tcp	*	Internet	15021	20.229.31.146
501	a1929606d68b24e5a97b71ff1ee27abf-TCP-80-Internet	Tcp	*	Internet	80	20.229.31.146
502	a1929606d68b24e5a97b71ff1ee27abf-TCP-443-Internet	Tcp	*	Internet	443	20.229.31.146
65000	AllowVnetInBound	*	*	VirtualNetwork	*	VirtualNetwork
65001	AllowAzureLoadBalancerInBound	*	*	AzureLoadBalancer	*	*
65500	DenyAllInBound	*	*	*	*	*

Outbound Security Rules

Priority	Name	Protocol	Source Port	Source Filter	Destination Port	Destination Filter	Action
65000	AllowVnetOutBound	*	*	VirtualNetwork	*	VirtualNetwork	✓
65001	AllowInternetOutBound	*	*	*	*	Internet	✓
65500	DenyAllOutBound	*	*	*	*	*	✗

Attached Subnets

None

Attached Network Interfaces



Priority	Name	Port	Protocol	Source	Destination	Action
100	AllIncomingTCP	Any	TCP	Any	Any	Allow
500	a1929606d68b24e5a97b...	15021	Tcp	Internet	20.229.31.146	Allow
501	a1929606d68b24e5a97b...	80	Tcp	Internet	20.229.31.146	Allow
502	a1929606d68b24e5a97b...	443	Tcp	Internet	20.229.31.146	Allow
65000	AllowVnetInbound	Any	Any	VirtualNetwork	VirtualNetwork	Allow
65001	AllowAzureLoadBalancer...	Any	Any	AzureLoadBalancer	Any	Allow
65500	DenyAllInBound	Any	Any	Any	Any	Deny

Remediation: From Azure Portal

We recommend that you edit the inbound rules of some of your virtual machines, to restrict access to specific source ranges.

To restrict access to your virtual machines:

1. Select a VM to restrict access to.
2. In the 'Networking' blade, click the Network Security Group with overly permissive rules.
3. In the 'Network security group' blade, click on each of the rules that are overly permissive.
4. Improve the rule by applying less permissive source IP ranges.
5. Apply the suggested changes and click 'Save'.

If some or all of these virtual machines do not need to be accessed directly from the Internet, then you can also consider removing the public IP associated to them.



Name	↑↓	Subscription
 webgl01		subs-xyz-hsc-nonprod
 webgl-windows		subs-xyz-hsc-nonprod
 vm-hsc-staging-jenkins		subs-xyz-hsc-nonprod
 vm-hsc-prod-jenkins		subs-xyz-hsc-prod
 vm-hsc-dev-jenkins		subs-xyz-hsc-nonprod
 vm-hsc-converter		subs-xyz-hsc-nonprod
 test-01		subs-xyz-hsc-nonprod
 powerbi		subs-xyz-hsc-nonprod

5.2.5.4 PRIVATE ENDPOINT SHOULD BE CONFIGURED FOR KEY VAULT

Private link provides a way to connect Key Vault to your Azure resources without sending traffic over the public internet. Private link provides defense in depth protection against data exfiltration.

Remediation: From Azure Portal

For detailed steps, see <https://aka.ms/akvprivatelink>.



Name	↑↓	Subscription
kv-xyz-hsc-staging-admin		subs-xyz-hsc-nonprod
kv-xyz-hsc-staging		subs-xyz-hsc-nonprod
kv-xyz-hsc-prod-admin		subs-xyz-hsc-prod
kv-xyz-hsc-prod		subs-xyz-hsc-prod
kv-xyz-hsc-dev-admin		subs-xyz-hsc-nonprod
kv-xyz-hsc-dev		subs-xyz-hsc-nonprod

5.2.5.5 CONTAINER REGISTRIES SHOULD NOT ALLOW UNRESTRICTED NETWORK ACCESS

Azure container registries by default accept connections over the internet from hosts on any network. To protect your registries from potential threats, allow access from only specific public IP addresses or address ranges. If your registry doesn't have an IP/firewall rule or a configured virtual network, it will appear in the unhealthy resources. Learn more about Container Registry network rules here: <https://aka.ms/acr/portal/public-network> and here <https://aka.ms/acr/vnet>.

Remediation: From Azure Portal

To enable VNet/Firewall rules for a registry:

1. In the Azure Portal, navigate to your registry in the Azure portal
2. Under Networking settings, on the Public access tab, select allow public access from 'Selected networks' instead of 'All Networks'
3. Under Firewall, enter a public IP address, such as the public IP address of a VM in a virtual network. Or, enter an address range in CIDR notation that contains the VM's IP address
4. Select save. For more information, see: <https://aka.ms/acr/portal/public-network> and <https://aka.ms/acr/vnet>.

Name	↑↓	Subscription
xyzacrstaging		subs-xyz-hsc-nonprod
xyzacrprod		subs-xyz-hsc-prod
xyzacrdev		subs-xyz-hsc-nonprod



5.2.5.6 KUBERNETES API SERVER SHOULD BE CONFIGURED WITH RESTRICTED ACCESS

To ensure that only applications from allowed networks, machines, or subnets can access your cluster, restrict access to your Kubernetes API server. You can restrict access by defining authorized IP ranges, or by setting up your API servers as private clusters as explained in [Create a private Azure Kubernetes Service cluster](#).

Remediation: From Azure Portal

Select the unhealthy resources and click “Fix” to launch “Quick fix” remediation. [Learn more >](#)

Note: After the process completes, it may take up to 30 min until your resources move to the ‘healthy resources’ tab.

Manual remediation:

To manually configure authorized IP ranges, follow the steps in [Secure access to the API server using authorized IP address ranges in Azure Kubernetes Service \(AKS\)](#). If your existing cluster uses a Basic SKU Load Balancer, you'll need to redeploy or migrate to a new AKS cluster using the Standard SKU Load Balancer as explained in [Moving from a basic SKU load balancer to standard SKU](#). If you decide not to redeploy, and you want to move these clusters to the 'not applicable' tab, follow the steps in [Define an exemption](#).

Name	↑↓	Subscription
 staging-aks		subs-xyz-hsc-nonprod
 prod-aks		subs-xyz-hsc-prod
 dev-aks		subs-xyz-hsc-nonprod

5.2.5.7 CONTAINER REGISTRIES SHOULD USE PRIVATE

Azure Private Link lets you connect your virtual network to Azure services without a public IP address at the source or destination. The private link platform handles the connectivity between the consumer and services over the Azure backbone network. By mapping private endpoints to your container registries instead of the entire service, you'll also be protected against data leakage risks. [Learn more at: https://aka.ms/acr/private-link](https://aka.ms/acr/private-link).



Remediation: From Azure Portal

To enable private links for a registry:

1. Ensure the registry's SKU is set to Premium (SKUs can be upgraded)
2. In the Private endpoints tab, under Network Settings, add basic endpoint information such as name and region
3. On the next page, add registry resource information (such as: name, resource type and subscription)
4. On the next page, add networking and private dns configuration.
5. Create the private endpoint resource. For more information, see: <https://aka.ms/acr/privatelink>

Name	↑↓	Subscription
 xyzacrstaging		subs-xyz-hsc-nonprod
 xyzacrprod		subs-xyz-hsc-prod
 xyzacrdev		subs-xyz-hsc-nonprod

5.2.5.8 MANAGEMENT PORTS SHOULD BE CLOSED ON YOUR VIRTUAL MACHINES

Open remote management ports are exposing your VM to a high level of risk from Internet-based attacks. These attacks attempt to brute force credentials to gain admin access to the machine.

Remediation: From Azure Portal

We recommend that you edit the inbound rules of some of your virtual machines, to restrict access to specific source ranges.

To restrict access to your virtual machines:

1. Select a VM to restrict access to.
2. In the 'Networking' blade, click on each of the rules that allow management ports (for example, RDP-3389, WINRM-5985, SSH-22).
3. Either change the 'Action' property to 'Deny', or, improve the rule by applying a less permissive range of source IP ranges.
4. Click 'Save'.

Use Defender for Cloud's Just-in-time (JIT) virtual machine (VM) access to lock down inbound traffic to your Azure VMs by demand. Learn more in Understanding just-in-time (JIT) VM access.



Name	Subscription
webgl01	subs-xyz-hsc-nonprod
webgl-windows	subs-xyz-hsc-nonprod
vm-hsc-staging-jenkins	subs-xyz-hsc-nonprod
vm-hsc-prod-jenkins	subs-xyz-hsc-prod
vm-hsc-dev-jenkins	subs-xyz-hsc-nonprod
vm-hsc-converter	subs-xyz-hsc-nonprod
test-01	subs-xyz-hsc-nonprod
powerbi	subs-xyz-hsc-nonprod

5.2.5.9 MANAGEMENT PORTS OF VIRTUAL MACHINES SHOULD BE PROTECTED WITH JUST-IN-TIME NETWORK ACCESS CONTROL

Defender for Cloud has identified some overly-permissive inbound rules for management ports in your Network Security Group. Enable just-in-time access control to protect your VM from internet-based brute-force attacks. Learn more in Understanding just-in-time (JIT) VM access.

Remediation: From Azure Portal

Quick fix:

Select the unhealthy resources and click "Fix" to launch "Quick fix" remediation. Learn more >

Note: After the process completes, it may take up to 24 hours until your resources move to the 'healthy resources' tab.

Manual remediation:

To enable just-in-time VM access:

- Select one or more VMs from the list below and select "Remediate", or select "Take action" if you've arrived from a recommendation for a specific VM.
- On the "JIT VM access configuration" page, define the ports for which the just-in-time VM access will be applicable.
 - To add additional ports, select the "Add" button on the top left, or select an existing port and edit it.
 - On the "Add port configuration" pane, enter the required parameters.



- Select "Save".

Name	↑↓	Subscription
 webgl01		subs-xyz-hsc-nonprod
 webgl-windows		subs-xyz-hsc-nonprod
 vm-hsc-staging-jenkins		subs-xyz-hsc-nonprod
 vm-hsc-prod-jenkins		subs-xyz-hsc-prod
 vm-hsc-dev-jenkins		subs-xyz-hsc-nonprod
 vm-hsc-converter		subs-xyz-hsc-nonprod
 test-01		subs-xyz-hsc-nonprod
 powerbi		subs-xyz-hsc-nonprod

5.2.5.10 VIRTUAL NETWORKS SHOULD BE PROTECTED BY AZURE FIREWALL

Some of your virtual networks aren't protected with a firewall. Use Azure Firewall to restrict access to your virtual networks and prevent potential threats. Learn more about Azure Firewall.

Remediation: From Azure Portal

To protect your virtual networks with Azure Firewall:

1. From the list below, select a network. Or select Take action if you've arrived here from a specific virtual network page.
2. Follow the Azure Firewall deployment instructions. Make sure to configure all default routes properly.

Important: Azure Firewall is billed separately from Defender for Cloud. Learn more about Azure Firewall pricing.



Name	↑↓	Subscription
 webgl01		subs-xyz-hsc-nonprod
 webgl-windows		subs-xyz-hsc-nonprod
 vm-hsc-staging-jenkins		subs-xyz-hsc-nonprod
 vm-hsc-prod-jenkins		subs-xyz-hsc-prod
 vm-hsc-dev-jenkins		subs-xyz-hsc-nonprod
 vm-hsc-converter		subs-xyz-hsc-nonprod
 test-01		subs-xyz-hsc-nonprod
 powerbi		subs-xyz-hsc-nonprod

5.2.6 VIRTUAL MACHINES

This section covers security recommendations to follow for the configuration of Virtual Machines on an Azure subscription.

5.2.7 KEY VAULT

This section covers security recommendations to follow for the configuration and use of Azure Key Vault.

5.2.7.1 VIRTUAL MACHINES SHOULD ENCRYPT TEMP DISKS, CACHES, AND DATA FLOWS BETWEEN COMPUTE AND STORAGE RESOURCES

By default, a virtual machine's OS and data disks are encrypted-at-rest using platform-managed keys; temp disks and data caches aren't encrypted, and data isn't encrypted when flowing between compute and storage resources.

For a comparison of different disk encryption technologies in Azure, see <https://aka.ms/diskencryptioncomparison>.

Use Azure Disk Encryption to encrypt all this data.

Disregard this recommendation if:

1. You're using the encryption-at-host feature, or



2. Server-side encryption on Managed Disks meets your security requirements.

Learn more in [Server-side encryption of Azure Disk Storage](#).

Remediation: From Azure Portal

To enable disk encryption on your virtual machines, follow Encryption instructions.

Name	Subscription
 webgl01	subs-xyz-hsc-nonprod
 webgl-windows	subs-xyz-hsc-nonprod
 vm-hsc-converter	subs-xyz-hsc-nonprod
 powerbi	subs-xyz-hsc-nonprod

5.2.8 APPSERVICE

This section covers security recommendations for Azure AppService.

5.2.8.1 9.2 ENSURE WEB APP REDIRECTS ALL HTTP TRAFFIC TO HTTPS IN AZURE APP SERVICE (AUTOMATED)

Azure Web Apps allows sites to run under both HTTP and HTTPS by default. Web apps can be accessed by anyone using non-secure HTTP links by default. Non-secure HTTP requests can be restricted, and all HTTP requests redirected to the secure HTTPS port. It is recommended to enforce HTTPS-only traffic.

Enabling HTTPS-only traffic will redirect all non-secure HTTP requests to HTTPS ports. HTTPS uses the TLS/SSL protocol to provide a secure connection which is both encrypted and authenticated. It is therefore important to support HTTPS for the security benefits



JobTriggerApp

Information

Name: JobTriggerApp
Resource Group: rg-hsc-dev-functions
Repository Site Name: JobTriggerApp
Location: West Europe
Last Modified Time: Wed Jul 27 2022 13:07:11 GMT+0100 (British Summer Time)
State: Stopped
Usage State: Normal
Availability State: Normal
Kind: functionapp, linux
Programming Language: python
Programming Language Version: 3.9
Tags:
hidden-link: /app-insights-resource-id:/subscriptions/c75fed9d-9b73-4771-b64d-175bab58d352/resourceGroups/rg-hsc-dev-functions/providers/microsoft.insights/components/JobTriggerApp
hidden-link: /app-insights-instrumentation-key:266f9d43-922c-443f-b416-8e48b9852328
hidden-link: /app-insights-conn-string:InstrumentationKey=266f9d43-922c-443f-b416-8e48b9852328;IngestionEndpoint=https://westeurope-5.in.applicationinsights.azure.com/LiveEndpoint=https://westeurope.livediagnostics.monitor.azure.com/

Configuration

Authentication: Unknown
HTTPS-Only Traffic: **Disabled**
HTTPS 2.0 Support: Disabled
HTTP Logging: Disabled
FTP Deployment : Enabled
Minimum TLS Version Supported: 1.2
Client Certificates: Disabled

Networking

Default Host Name: jobtriggerapp.azurewebsites.net

Outbound IP Addresses:

- 52.178.92.96
- 51.144.224.93
- 52.232.70.142
- 52.232.4.132
- 52.232.64.246

Possible Outbound IP Addresses:

- 52.178.92.96
- 51.144.224.93
- 52.232.70.142
- 52.232.4.132
- 52.232.64.246
- 51.145.159.13
- 52.136.236.15



Name



Subscription

subs-xyz-hsc-nonprod

Remediation:**From Azure Portal**

1. Login to Azure Portal using <https://portal.azure.com>
2. Go to App Services
3. Click on each App
4. Under Setting section, Click on TLS/SSL settings
5. Under the Bindings pane, set HTTPS Only to On under Protocol Settings section

From Azure CLI

To set HTTPS-only traffic value for an existing app, run the following command:

```
az webapp update --resource-group <RESOURCE_GROUP_NAME> --name <APP_NAME> -- set httpsOnly=true
```

From Powershell

```
Set-AzWebApp -ResourceGroupName <RESOURCE_GROUP_NAME> -Name <APP_NAME> - HttpsOnly $true
```

Default Value:

By default, HTTPS-only feature will be disabled when a new app is created using the command-line tool or Azure Portal console.

References:

1. <https://docs.microsoft.com/en-us/azure/app-service/app-service-web-tutorial-custom-ssl#enforce-https>
2. <https://docs.microsoft.com/en-us/security/benchmark/azure/security-controls-v3-data-protection#dp-3-encrypt-sensitive-data-in-transit>
3. <https://docs.microsoft.com/en-us/powershell/module/az.websites/set-azwebapp?view=azps-8.1.0>



5.2.8.2 9.4 ENSURE THE WEB APP HAS 'CLIENT CERTIFICATES (INCOMING CLIENT CERTIFICATES)' SET TO 'ON' (AUTOMATED)

Client certificates allow for the app to request a certificate for incoming requests. Only clients that have a valid certificate will be able to reach the app.

The TLS mutual authentication technique in enterprise environments ensures the authenticity of clients to the server. If incoming client certificates are enabled, then only an authenticated client who has valid certificates can access the app.

Utilizing and maintaining client certificates will require additional work to obtain and manage replacement and key rotation.



JobTriggerApp

Information

Name: JobTriggerApp
Resource Group: rg-hsc-dev-functions
Repository Site Name: JobTriggerApp
Location: West Europe
Last Modified Time: Wed Jul 27 2022 13:07:11 GMT+0100 (British Summer Time)
State: Stopped
Usage State: Normal
Availability State: Normal
Kind: functionapp, linux
Programming Language: python
Programming Language Version: 3.9
Tags:
hidden-link: /app-insights-resource-id:/subscriptions/c75fed9d-9b73-4771-b64d-175bab58d352
/resourceGroups/rg-hsc-dev-functions/providers/microsoft.insights/components/JobTriggerApp
hidden-link: /app-insights-instrumentation-key:266f9d43-922c-443f-b416-8e48b9852328
hidden-link: /app-insights-conn-string:InstrumentationKey=266f9d43-922c-443f-b416-8e48b9852328;IngestionEndpoint=https://westeurope-5.in.applicationinsights.azure.com
/;LiveEndpoint=https://westeurope.livediagnostics.monitor.azure.com/

Configuration

Authentication: Unknown
HTTPS-Only Traffic: Disabled
HTTPS 2.0 Support: Disabled
HTTP Logging: Disabled
FTP Deployment : Enabled
Minimum TLS Version Supported: 1.2
Client Certificates: Disabled

Networking

Default Host Name: jobtriggerapp.azurewebsites.net

Outbound IP Addresses:

- 52.178.92.96
- 51.144.224.93
- 52.232.70.142
- 52.232.4.132
- 52.232.64.246

Possible Outbound IP Addresses:

- 52.178.92.96
- 51.144.224.93
- 52.232.70.142
- 52.232.4.132
- 52.232.64.246
- 51.145.159.13
- 52.136.236.15

**Remediation:****From Azure Portal**

1. Login to Azure Portal using <https://portal.azure.com>
2. Go to App Services
3. Click on each App
4. Under the Settings section, Click on Configuration, then General settings
5. Set the option Client certificate mode located under Incoming client certificates is set to Require

From Azure CLI

To set Incoming client certificates value for an existing app, run the following command:

```
az webapp update --resource-group <RESOURCE_GROUP_NAME> --name <APP_NAME> -- set clientCertEnabled=true
```

Default Value:

By default, incoming client certificates will be disabled when a new app is created using the command-line tool or Azure Portal console.

References:

1. <https://docs.microsoft.com/en-us/security/benchmark/azure/security-controls-v3-identity-management#im-4-authenticate-server-and-services>



5.2.8.3 9.9 ENSURE THAT 'HTTP VERSION' IS THE LATEST, IF USED TO RUN THE WEB APP (AUTOMATED)

Periodically, newer versions are released for HTTP either due to security flaws or to include additional functionality. Using the latest HTTP version for web apps to take advantage of security fixes, if any, and/or new functionalities of the newer version.

Newer versions may contain security enhancements and additional functionality. Using the latest version is recommended in order to take advantage of enhancements and new capabilities. With each software installation, organizations need to determine if a given update meets their requirements. They must also verify the compatibility and support provided for any additional software against the update revision that is selected. HTTP 2.0 has additional performance improvements on the head-of-line blocking problem of old HTTP version, header compression, and prioritization of requests. HTTP 2.0 no longer supports HTTP 1.1's chunked transfer encoding mechanism, as it provides its own, more efficient, mechanisms for data streaming.



JobTriggerApp

Information

Name: JobTriggerApp
Resource Group: rg-hsc-dev-functions
Repository Site Name: JobTriggerApp
Location: West Europe
Last Modified Time: Wed Jul 27 2022 13:07:11 GMT+0100 (British Summer Time)
State: Stopped
Usage State: Normal
Availability State: Normal
Kind: functionapp, linux
Programming Language: python
Programming Language Version: 3.9
Tags:
hidden-link: /app-insights-resource-id:/subscriptions/c75fed9d-9b73-4771-b64d-175bab58d352/resourceGroups/rg-hsc-dev-functions/providers/microsoft.insights/components/JobTriggerApp
hidden-link: /app-insights-instrumentation-key:266f9d43-922c-443f-b416-8e48b9852328
hidden-link: /app-insights-conn-string:InstrumentationKey=266f9d43-922c-443f-b416-8e48b9852328;IngestionEndpoint=https://westeurope-5.in.applicationinsights.azure.com/LiveEndpoint=https://westeurope.livediagnostics.monitor.azure.com/

Configuration

Authentication: Unknown
HTTPS-Only Traffic: Disabled
HTTPS 2.0 Support: Disabled
HTTP Logging: Disabled
FTP Deployment: Enabled
Minimum TLS Version Supported: 1.2
Client Certificates: Disabled

Networking

Default Host Name: jobtriggerapp.azurewebsites.net

Outbound IP Addresses:

- 52.178.92.96
- 51.144.224.93
- 52.232.70.142
- 52.232.4.132
- 52.232.64.246

Possible Outbound IP Addresses:

- 52.178.92.96
- 51.144.224.93
- 52.232.70.142
- 52.232.4.132
- 52.232.64.246
- 51.145.159.13
- 52.136.236.15

**Remediation:** From Azure Portal

1. Login to Azure Portal using <https://portal.azure.com>
2. Go to App Services
3. Click on each App
4. Under Setting section, Click on Configuration
5. Set HTTP version to 2.0 under General settings

NOTE: Most modern browsers support HTTP 2.0 protocol over TLS only, while non-encrypted traffic continues to use HTTP 1.1. To ensure that client browsers connect to your app with HTTP/2, either buy an App Service Certificate for your app's custom domain or bind a third party certificate.

From Azure CLI

To set HTTP 2.0 version for an existing app, run the following command:

```
az webapp config set --resource-group <RESOURCE_GROUP_NAME> --name <APP_NAME> --http20-enabled true
```

From PowerShell

To enable HTTP 2.0 version support, run the following command:

```
Set-AzWebApp -ResourceGroupName <app resource group> -Name <app name> - Http20Enabled $true
```

References:

1. <https://docs.microsoft.com/en-us/azure/app-service/web-sites-configure#general-settings>
2. <https://docs.microsoft.com/en-us/security/benchmark/azure/security-controls-v3-posture-vulnerability-management#pv-7-rapidly-and-automatically-remediate-software-vulnerabilities>
3. <https://docs.microsoft.com/en-us/security/benchmark/azure/security-controls-v3-posture-vulnerability-management#pv-3-establish-secure-configurations-for-compute-resources>.



5.2.8.4 9.10 ENSURE FTP DEPLOYMENTS ARE DISABLED (AUTOMATED)

By default, Azure Functions, Web, and API Services can be deployed over FTP. If FTP is required for an essential deployment workflow, FTPS should be required for FTP login for all App Service Apps and Functions.

Azure FTP deployment endpoints are public. An attacker listening to traffic on a Wi-Fi network used by a remote employee, or a corporate network could see login traffic in clear-text which would then grant them full control of the code base of the app or service. This finding is more severe if User Credentials for deployment are set at the subscription level rather than using the default Application Credentials which are unique per App.

Any deployment workflows that rely on FTP or FTPs rather than the WebDeploy or HTTPs endpoints may be affected.



JobTriggerApp

Information

Name: JobTriggerApp
Resource Group: rg-hsc-dev-functions
Repository Site Name: JobTriggerApp
Location: West Europe
Last Modified Time: Wed Jul 27 2022 13:07:11 GMT+0100 (British Summer Time)
State: Stopped
Usage State: Normal
Availability State: Normal
Kind: functionapp, linux
Programming Language: python
Programming Language Version: 3.9
Tags:
hidden-link: /app-insights-resource-id:/subscriptions/c75fed9d-9b73-4771-b64d-175bab58d352/resourceGroups/rg-hsc-dev-functions/providers/microsoft.insights/components/JobTriggerApp
hidden-link: /app-insights-instrumentation-key:266f9d43-922c-443f-b416-8e48b9852328
hidden-link: /app-insights-conn-string:InstrumentationKey=266f9d43-922c-443f-b416-8e48b9852328;IngestionEndpoint=https://westeurope-5.in.applicationinsights.azure.com/LiveEndpoint=https://westeurope.livediagnostics.monitor.azure.com/

Configuration

Authentication: Unknown
HTTPS-Only Traffic: Disabled
HTTPS 2.0 Support: Disabled
HTTP Logging: Disabled
FTP Deployment: **Enabled**
Minimum TLS Version Supported: 1.2
Client Certificates: Disabled

Networking

Default Host Name: jobtriggerapp.azurewebsites.net

Outbound IP Addresses:

- 52.178.92.96
- 51.144.224.93
- 52.232.70.142
- 52.232.4.132
- 52.232.64.246

Possible Outbound IP Addresses:

- 52.178.92.96
- 51.144.224.93
- 52.232.70.142
- 52.232.4.132
- 52.232.64.246
- 51.145.159.13
- 52.136.236.15

**Remediation:****From Azure Portal**

1. Go to the Azure Portal
2. Select App Services
3. Click on an app
4. Select Settings and then Configuration
5. Under General Settings, for the Platform Settings, the FTP state should be set to Disabled or FTPS Only

From Azure CLI

List webapps to obtain the ids.

```
az webapp list
```

List the publish profiles to obtain the username, password and ftp server url.

```
az webapp deployment list-publishing-profiles --ids <ids>

{
  "publishUrl": <URL_FOR_WEB_APP>,
  "userName": <USER_NAME>,
  "userPWD": <USER_PASSWORD>,
}
```

From Azure CLI

For each out of compliance application, run the following choosing either 'disabled' or 'FtpsOnly' as appropriate:

```
az webapp config set --resource-group <resource group name> --name <app name> --ftps-state [disabled|FtpsOnly]
```

From PowerShell

For each out of compliance application, run the following:

```
Set-AzWebApp -ResourceGroupName <resource group name> -Name <app name> - FtpsState <Disabled or FtpsOnly>
```



Default Value:

By default, FTP based deployment is All allowed

References:

1. [Azure Web Service Deploy via FTP] (<https://docs.microsoft.com/en-us/azure/app-service/deploy-ftp>)
2. [Azure Web Service Deployment] (<https://docs.microsoft.com/en-us/azure/app-service/overview-security>)
3. <https://docs.microsoft.com/en-us/security/benchmark/azure/security-controls-v3-data-protection#dp-4-encrypt-sensitive-information-in-transit>
4. <https://docs.microsoft.com/en-us/security/benchmark/azure/security-controls-v3-posture-vulnerability-management#pv-7-rapidly-and-automatically-remediate-software-vulnerabilities>



JobTriggerApp

Information

Name: JobTriggerApp
Resource Group: rg-hsc-dev-functions
Repository Site Name: JobTriggerApp
Location: West Europe
Last Modified Time: Wed Jul 27 2022 13:07:11 GMT+0100 (British Summer Time)
State: Stopped
Usage State: Normal
Availability State: Normal
Kind: functionapp, linux
Programming Language: python
Programming Language Version: 3.9
Tags:
hidden-link: /app-insights-resource-id:/subscriptions/c75fed9d-9b73-4771-b64d-175bab58d352
/resourceGroups/rg-hsc-dev-functions/providers/microsoft.insights/components/JobTriggerApp
hidden-link: /app-insights-instrumentation-key:266f9d43-922c-443f-b416-8e48b9852328
hidden-link: /app-insights-conn-string:InstrumentationKey=266f9d43-922c-443f-b416-8e48b9852328;IngestionEndpoint=https://westeurope-5.in.applicationinsights.azure.com
/;LiveEndpoint=https://westeurope.livediagnostics.monitor.azure.com/

Configuration

Authentication: Unknown
HTTPS-Only Traffic: Disabled
HTTPS 2.0 Support: Disabled
HTTP Logging: Disabled
FTP Deployment: Enabled
Minimum TLS Version Supported: 1.2
Client Certificates: Disabled

Networking

Default Host Name: jobtriggerapp.azurewebsites.net

Outbound IP Addresses:

- 52.178.92.96
- 51.144.224.93
- 52.232.70.142
- 52.232.4.132
- 52.232.64.246

Possible Outbound IP Addresses:

- 52.178.92.96
- 51.144.224.93
- 52.232.70.142
- 52.232.4.132
- 52.232.64.246
- 51.145.159.13
- 52.136.236.15

**Name****Subscription** jobtriggerapp

subs-xyz-hsc-nonprod



6 APPENDIX

6.1 TEST CASES

6.1.1 INFORMATION GATHERING

- **Rendered Site Review**
 - Manually explore the site
 - Spider/crawl for missed or hidden content
 - Check the webserver metafiles for information leakage files that expose content, such as robots.txt, sitemap.xml
 - Check for differences in content based on user agent (e.g. mobile sites, accessing as a search engine crawler)
 - Check webpage comments and metadata for information leakage

- **Development Review**
 - Check the web application framework
 - Perform web application fingerprinting
 - Identify technologies used
 - Identify user roles
 - Identify application entry points
 - Identify client-side code
 - Identify multiple versions/channels (e.g. web, mobile web, mobile app)

6.1.2 CONFIGURATION MANAGEMENT

- Check for commonly used application and administrative URLs
- Check for old, backup, and unreferenced files
- Check HTTP methods supported and Cross Site Tracing (XST)



- Test file extensions handling
- Test for security HTTP headers (e.g. CSP, X-Frame-Options, HSTS)
- Test for policies (e.g. Flash, Silverlight, robots)
- Check for sensitive data in client-side code (e.g. API keys, credentials)

6.1.3 AUTHENTICATION

- **Application Password Functionality**
 - Test password quality rules
 - Test remember me functionality
 - Test password reset and/or recovery
 - Test password change process
 - Test CAPTCHA
 - Test multi-factor authentication
 - Test for logout functionality presence
 - Test for default logins
 - Test for out-of-channel notification of account lockouts and successful password changes
 - Test for consistent authentication across applications with shared authentication schema/SSO and alternative channels
 - Test for weak security question/answer



- **Additional Authentication Functionality**

- Test for user enumeration
- Test for authentication bypass
- Test for brute force protection
- Test for credentials transported over an encrypted channel
- Test for cache management on HTTP (e.g. Pragma, Expires, Max-age)
- Test for user-accessible authentication history

6.1.4 SESSION MANAGEMENT

- Establish how session management is handled in the application (e.g., tokens in cookies, token in URL)
- Check session tokens for cookie flags (httpOnly and secure)
- Check session cookie scope (path and domain)
- Check session cookie duration (expires and max-age)
- Check session termination after a maximum lifetime
- Check session termination after relative timeout
- Check session termination after logout
- Test to see if users can have multiple simultaneous sessions
- Test session cookies for randomness
- Confirm that new session tokens are issued on login, role change, and logout
- Test for consistent session management across applications with shared session management



- Test for session puzzling
- Test for CSRF and clickjacking

6.1.5 AUTHORIZATION

- Test for path traversal
- Test for vertical access control problems (a.k.a. privilege escalation)
- Test for horizontal access control problems (between two users at the same privilege level)
- Test for missing authorization
- Test for insecure direct object references

6.1.6 DATA VALIDATION

- **Injection**
 - Test for HTML Injection
 - Test for SQL Injection
 - Test for LDAP Injection
 - Test for XML Injection
 - Test for XPath Injection
 - Test for Code Injection
 - Test for Command Injection
 - Test for NoSQL injection



- **Other**

- Test for Reflected Cross Site Scripting
- Test for Stored Cross Site Scripting
- Test for DOM based Cross Site Scripting
- Test for Overflow (Stack, Heap and Integer)
- Test for Format String
- Test for HTTP Splitting/Smuggling
- Test for HTTP Verb Tampering
- Test for Open Redirection
- Test for Local File Inclusion
- Test for Remote File Inclusion
- Compare client-side and server-side validation rules
- Test for HTTP parameter pollution
- Test for auto-binding
- Test for NULL/Invalid Session Cookie
- Test for integrity of data
- Test for the Circumvention of Work Flows
- Test Defences Against Application Mis-use
- Test That a Function or Feature Cannot Be Used Outside of Limits
- Test for Process Timing



6.1.7 DENIAL OF SERVICE

- Test for anti-automation
- Test for account lockout

6.1.8 SPECIFIC RISKY FUNCTIONALITY

- **File Uploads**
 - Test that acceptable file types are whitelisted and non-whitelisted types are rejected
 - Test that file contents match the defined file type
 - Test upload of malicious files
 - Test that unsafe filenames are sanitized
 - Test that uploaded files are not directly accessible within the web root
 - Test that files and other media are integrated with the authentication and authorization schemas

6.1.9 ERROR HANDLING

- Check for Error Codes
- Check for Stack Traces



6.2 OWASP TOP 10

The Open Web Application Security Project (OWASP) is a not-for-profit worldwide charitable organisation focused on improving the security of application software. One of the resources provided by the OWASP is a list of the top 10 most common threats to application security.

The OWASP Top 10 was adopted by the Payment Card Industry (PCI) for inclusion within the PCI Data Security Standards document. Any organisation that processes, stores or transmits Card Holder Data must ensure their applications have been designed securely and tested for all vulnerabilities listed within the OWASP Top 10.

The following categories comprise the current and previous top ten vulnerabilities as reported by OWASP and are each analysed and tested for when conducting application testing, as well as other common vulnerability classes.

6.2.1 A1: INJECTION

Injection flaws, such as SQL, NoSQL, OS, and LDAP injection occur when untrusted data is sent to an interpreter as part of a command or query. The attacker's hostile data can trick the interpreter into executing unintended commands or accessing data without proper authorisation.

6.2.2 A2: BROKEN AUTHENTICATION

Application functions related to authentication and session management are often implemented incorrectly, allowing attackers to compromise passwords, keys, or session tokens, or to exploit other implementation flaws to assume other users' identities temporarily or permanently.

6.2.3 A3: SENSITIVE DATA EXPOSURE

Many web applications and APIs do not properly protect sensitive data, such as financial, healthcare, and PII. Attackers may steal or modify such weakly protected data to conduct credit card fraud, identity theft, or other crimes. Sensitive data may be compromised without extra protection, such as encryption at rest or in transit, and requires special precautions when exchanged with the browser.

6.2.4 A4: XML EXTERNAL ENTITIES (XXE)

Many older or poorly configured XML processors evaluate external entity references within XML documents. External entities can be used to disclose internal files using the file URI handler, internal file shares, internal port scanning, remote code execution, and denial of service attacks.

6.2.5 A5: BROKEN ACCESS CONTROL



Restrictions on what authenticated users are allowed to do are often not properly enforced. Attackers can exploit these flaws to access unauthorized functionality and/or data, such as access other users' accounts, view sensitive files, modify other users' data, change access rights, etc.

6.2.6 A6: SECURITY MISCONFIGURATION

Security misconfiguration is the most commonly seen issue. This is commonly a result of insecure default configurations, incomplete or ad hoc configurations, open cloud storage, misconfigured HTTP headers, and verbose error messages containing sensitive information. Not only must all operating systems, frameworks, libraries, and applications be securely configured, but they must be patched and upgraded in a timely fashion.

6.2.7 A7: CROSS-SITE SCRIPTING (XSS)

XSS flaws occur whenever an application includes untrusted data in a new web page without proper validation or escaping, or updates an existing web page with user-supplied data using a browser API that can create HTML or JavaScript.

XSS allows attackers to execute scripts in the victim's browser which can hijack user sessions, deface web sites, or redirect the user to malicious sites.

6.2.8 A8: INSECURE DESERIALIZATION

Insecure deserialization often leads to remote code execution. Even if deserialization flaws do not result in remote code execution, they can be used to perform attacks, including replay attacks, injection attacks, and privilege escalation attacks.

6.2.9 A9: USING COMPONENTS WITH KNOWN VULNERABILITIES

Components, such as libraries, frameworks, and other software modules, run with the same privileges as the application.

If a vulnerable component is exploited, such an attack can facilitate serious data loss or server takeover. Applications and APIs using components with known vulnerabilities may undermine application defences and enable various attacks and impacts.

6.2.10 A10: INSUFFICIENT LOGGING & MONITORING

Insufficient logging and monitoring, coupled with missing or ineffective integration with incident response, allows attackers to further attack systems, maintain persistence, pivot to more systems, and tamper, extract, or destroy data.



Most breach studies show time to detect a breach is over 200 days, typically detected by external parties rather than internal processes or monitoring.



6.3 USED TOOLS

The tools used during the pentest are as follows:

- **PortSwigger Burp Suite Professional 2022.10.1** – an advanced set of tools for testing web security, from a basic intercepting proxy to a cutting-edge vulnerability scanner.
- **Kali Linux – v2022.3/** Kali Linux is an open-source project that is maintained and funded by Offensive Security, a provider of world-class information security training and penetration testing services.
- **Windows 10 Enterprise Edition:** Windows 10 is a major release of the Windows NT operating system developed by Microsoft
- **Postman** - is a scalable API testing tool that quickly integrates into CI/CD pipeline
- **Process Monitor v3.85:** Process Monitor is an advanced monitoring tool for Windows that shows real-time file system, Registry and process/thread activity.
- **Process Explorer v16.43:** Process Explorer is a freeware task manager and system monitor for Microsoft Windows created by SysInternals, which has been acquired by Microsoft and re-branded as Windows Sysinternals. It provides the functionality of Windows Task Manager along with a rich set of features for collecting information about processes running on the user's system. It can be used as the first step in debugging software or system problems.
- **hopperapp** : Hopper Disassembler, the reverse engineering tool that lets you disassemble, decompile and debug your applications.
- **Immunity Debugger** : Immunity Debugger is a powerful new way to write exploits, analyze malware, and reverse engineer binary files. It builds on a solid user interface with function graphing, the industry's first heap analysis tool built specifically for heap creation, and a large and well supported Python API for easy extensibility.
- **Autodesk Revit** : is a building information modelling software for architects, landscape architects, structural engineers, mechanical, electrical, and plumbing (MEP) engineers, designers and contractors.

In addition, standard network tools were used for accessing and reviewing exposed systems (e.g. web browsers, telnet, etc.), as well as standard system utilities and tools for network security analysis, such as ping and traceroute.



6.4 ROOT CAUSES

Identifying the root cause of a security issue is important to an effective and durable remediation strategy. Based on the testing performed, we have identified the following as the root causes for these security issues. A combination of a tactical (near-term) approach to remediate the observed vulnerabilities and a strategic (long-term) remediation approach to address the root causes of the identified vulnerabilities has been found to be a highly effective remediation approach.

TABLE 3 - ROOT CAUSES

Root Cause	Description
Insecure configuration	Insecure configuration can lead to security issues, such as unnecessary services, default accounts and passwords, overly informative error messages, services deployed in an insecure fashion and system information revealed to unauthorized users affecting the confidentiality, integrity, and availability of the affected systems.
Improper patch management	Inconsistent patching may result in systems or services that contain known vulnerabilities that may be easily exploitable by attackers.
Lack of adequate security awareness	Lack of security awareness among employees may result in unauthorized access to or disclosure of sensitive information.
Improper security architecture	Architecture and design related weaknesses in systems, software, network and/or security controls that could lead to unauthorized access, compromise, or disruption of services.
Insecure coding practices	Insecure coding practices comprise software coding issues related to improper error and exception handling, session management, input validation etc.



6.5 TERMINOLOGY

The following terms are used throughout this document:

- **Application-layer testing:** Testing that typically includes websites, web applications, thick clients, or other applications.
- **Black-box testing:** Testing performed without prior knowledge of the internal structure/design/implementation of the object being tested.
- **Common Vulnerability Scoring System (CVSS):** Provides an open framework for communicating the characteristics and impacts of IT vulnerabilities.
- **Grey-box testing:** Testing performed with partial knowledge of the internal structure/design/implementation of the object being tested.
- **National Vulnerability Database (NVD):** The U.S. government repository of standards-based vulnerability management data. This data enables automation of vulnerability management, security measurement, and compliance (e.g., FISMA).
- **Network-layer testing:** Testing that typically includes external/internal testing of networks (LANS/VLANS), between interconnected systems, and wireless networks.
- **Penetration tester, tester, or team:** The individual(s) conducting the penetration test for the entity. They may be a resource internal or external to the entity.